

Access Controls Management System

Department of Information Technology Management, Toronto Metropolitan University

ITM900 021: Capstone Project

1. Project Management	4
1.1 Project Charter	4
<i>Project Goals, Business Outcomes and Objectives</i>	10
<i>Project Scope</i>	10
<i>Scope Definition</i>	10
<i>Boundaries</i>	11
<i>Milestones</i>	11
<i>Deliverables</i>	12
<i>Dependencies</i>	14
<i>Project Risks, Assumptions, and Constraints</i>	14
<i>Risks</i>	14
<i>Assumptions</i>	16
<i>Constraints</i>	16
<i>Project Organization</i>	17
<i>Project Governance</i>	17
<i>Project Team Structure</i>	18
<i>Roles and Responsibilities</i>	19
<i>Project Facilities and Resources</i>	19
<i>Project References</i>	20
<i>Glossary and Acronyms</i>	21
1.2 Project Schedule	22
2. Identification of the problems and opportunities	23
2.1 Overview of the problem(s)/opportunities	24
2.2 Diagnostic (causes-problem-consequences)	25
3. Requirement Specification & Modeling	27
3.1. Use Case Model	28
3.2 Fully developed use case descriptions	29
4. Business Process Modeling (As-is and To-be diagrams)	39
4.1 BPMN Model Diagrams	40
<i>BPMN Design</i>	41
<i>BPMN To-Be</i>	41
5. Data Modeling & Design of the new IS solution	42
5.1. Entity Relationship Diagram	43
5.2. Database schema	45
6. Structural & Behavioral Design of the new IS solution	46
6.1. Class Diagram	47
6.2. Sequence diagrams	48

7. Proof-of-Concept Implementation prototype	50
7.1 Prototype Modules	51
SQL Database Code	51
CRUD Commands	57
Requester Data Ingestion	57
Central Authority Data Ingestion	59
Department Manager Data Ingestion	60
System Data Ingestion	61
Fileshare Data Ingestion	62
Access Request Data Ingestion	64
SQL Database Prototype	65
Use Case 1: Create	65
Use Case 2: Read	66
Use Case 3: Update	68
Use Case 4: Delete	69
Client Wireframes Microsoft Power Apps User Interface Provided by Client (UI)	71
Use Case 1: Requester onboarding	71
Requester Onboarding Form	71
Use Case 2: Access to Specific Systems	71
System Access Microsoft PowerApps Interface	71
8. Implementation and deployment & risk management plan for the new IS solution	72
8.1 Implementation and deployment activities	73
8.2 Risk assessment and mitigation activities	74
9. Client Organization Feedback	76
ITM Capstone Project Community Partnership	77
Mid-Semester Organization Feedback	78
End-of-Semester Organization Feedback	79
References	81

1. Project Management

1.1 Project Charter



**Access Controls Management System
Business Projects-IT-Enabled
Project Management Phase**

Section 1. Charter Introduction

Document Change Control

Revision Number	Date of Issue	Author(s)	Brief Description of Change
1.0			

Executive Summary

International Custom Products (ICP) is a textile company based in Canada, serving various institutional, government, and defense contractors. The company is committed to achieving full compliance with NIST 800-171 and the CMMC framework. Currently, their systems are decentralized, lacking a centralized management platform for tracking and approvals. To address this, the Toronto Metropolitan University (TMU) Capstone Team will analyze existing process flows and collaborate to create a new process flow with documentation using Microsoft Power Apps. Additionally, students will generate appropriate UML diagrams to share with Golden Integrated Solutions (GIS), their managed services provider responsible for the development team. The TMU Capstone Team will formalize the project in a comprehensive project charter, gaining insights into effective scope management and understanding the software development life cycle. The ultimate objective is to leverage Microsoft Power Apps to automate approval processes, maintain access logs, and enhance overall organizational efficiency. The student team will create a simulated SQL database using MySQL server and MySQL Workbench to support the development of this tool for the client's use.

This project seeks to respond to the existing challenges within the System Access/Provisioning process, especially with regards to documentation and traceability as tracking requests that present risks for securing Export Controlled Unclassified Information (CUI). The project was started as a result of the use of inefficient oral or email communication and aimed at introducing an all-comprehensive system solution. This solution will automate the entire process, including advanced access controls compliant with NIST and CUI standards, in order to increase data protection.

Key Aspects of the Project

Initiation: The project came about to address the lack of effectiveness and security weaknesses that are bound to the System Access/Provisioning process. The lack of documentation and tracking necessitated a total digital solution to guarantee adherence to security standards.

End Users: The last deliverable in the project will be used by ICP as a provider of applicable solutions to their challenges within the System Access/Provisioning process. They will benefit from a better and safer access request system that ensures security of confidential information.

Impacted Stakeholders: There are two main groups of stakeholders that stand to be affected by the project, and they include both internal and external parties linked to anticipated access provisioning process. These include employees that need access, administrators managing

requests for such employee needs and regulatory bodies ensuring compliance with security standards.

Executive Summary Elements

Project Goals and Objectives: The project targets to insure data access, acquire stakeholders' approvals, establish user controls to facilitate sufficient control policies, and achieve competent information management processes.

Major Milestones: Key steps include the creation of the project charter, which is responsible for defining all aspects and purposes of a new IS solution and implementation; a schedule (Gantt chart), problem settlement/opportunities identification, requirements specification, business process models, data modeling design associated with creating appropriate relatives schema development, proof-of concept interim operational prototype resulting from deployment and risk management.

Key Deliverables: Among the key deliverables is the completeness of a full system for System Access/Provisioning process, as well as documentation and tracking issues that are completed with effective access controls and compliance measures.

Key Risks: Major risk areas include the potential for delays in implementation, resistance from stakeholders, compliance pitfalls, and difficulties inevitably arising from the development or deployment of a new IS solution. Risk assessment and mitigation activities are embedded in the project plan.

Authorization

This project charter formally authorizes the existence of the project, System Access/Provisioning process digitization, and provides the project manager with the authority to apply organizational resources to the project activities described herein. If there is a change in the project scope, the project charter will be updated and submitted for re-approval.

Rodin Lozada
Executive Project Sponsor
Vice President Finance, ICP

Date: February 20, 2024

Stanley Yim
Steering Committee
Managing Director, GIS

Date: February 20, 2024

Michael Leung
Steering Committee
Manager, GIS

Date: February 20, 2024

Astha Maskey Tamang
Communications Project Manager, *TMU Capstone Team*

Date: February 20, 2024

Matthew Drumonde
Technical Project Manager, *TMU Capstone Team*

Date: February 20, 2024

Amanuel Mulualet Dinberu
Senior Business Analyst, *TMU Capstone Team*

Date: February 20, 2024

Faizan Ikram
Senior Business Analyst, *TMU Capstone Team*

Date: February 20, 2024

Alicia Kung
Business Analyst, *TMU Capstone Team*

Date: February 20, 2024

Hunaiza Ali
Business Analyst, *TMU Capstone Team*

Date: February 20, 2024

Project Overview

Project Summary

The TMU Capstone team is developing a Power Apps-based process flow to digitize the System Access/Provisioning process, ensuring NIST Compliance and CUI standards. Collaborating with Golden Integrated Solutions, the project aims to address challenges in handling Export Controlled Unclassified Information (CUI) requests, driven by inefficient communication. The initiative seeks to replace oral and email methods with a comprehensive system solution, incorporating automation and advanced access controls. UML diagrams will aid development, ultimately enhancing security and traceability, aligning with NIST and CUI standards for a robust and compliant digitized access control system.

NIST Compliance

NIST compliance involves adhering to standards and guidelines established by the National Institute of Standards and Technology (NIST) to enhance cybersecurity and IT practices. NIST, a non-regulatory agency under the U.S. Department of Commerce, publishes key documents like "NIST Special Publication 800-53," offering comprehensive security controls for federal information systems. Some of the security controls outlined in NIST SP 800-53 compliance are access control, identification and authentication, and configuration management. Compliance with NIST ensures only authorized users have access privileges, users and devices have valid identification and the rights they need to access systems, and all configurations address the latest needs of the system without compromising security. The NIST 800-171 Revision 2 Access Controls section describes the security controls needed for defense contractors that are involved in manufacturing and protecting Controlled Unclassified Information (CUI) in non-federal systems. Important points consist of restrictions on authorized entities as far as system access is concerned, control of information flow, and segregation duties. The principle of least privilege is upheld, particularly with remote or wireless access. The guidelines also include session management, encryption, and controls for mobile devices, external systems, and publicly accessible platforms. These actions are taken in order to ensure safe access, maintain data secrecy, and reduce risks when processing CUI information across multiple system domains (Fortinet, 2024).

Export Controlled CUI

CUI means controlled unclassified information, the release of which is subject to either safeguarding or dissemination controls pursuant to and consistent with applicable laws, regulations, and government policies. CUI includes sensitive information that is restricted from public disclosure while not classified due to its sensitive nature. Examples of CUI include certain types of financial, health, proprietary, or personally identifiable information, as well as information related to critical infrastructure, law enforcement, and defense. CUI as a category includes several subcategories, one of which is "Export Controlled," which implies information subject to export control laws and compensation requirements. In the sphere of export control, this term usually means information that, if provided to foreign citizens or legal entities, might pose implications in regard to national security and violations of laws regarding exports. The

export control regulations aim at ensuring that technologies, products, or information are not illegally transferred because this might lead to the development of weapons or other technologies that pose a threat. Protecting Export Controlled CUI requires robust measures like access controls, encryption, and compliance with regulations such as International Traffic in Arms Regulations (ITAR) and Export Administration Regulations (EAR). These precautions prevent unauthorized access and ensure adherence to export control laws, safeguarding sensitive information and mitigating legal risks. The CUI Banner Marking is the main marking for all CUI. It is mandatory for all documents containing CUI to contain this marking. This marking must follow two guidelines: Must be inclusive of all CUI while being the same on every page and the writing must be bold, capitalized, with black text and be centered. In the context of Export Control the CUI banner marking must consist of the word “CONTROLLED” or the acronym “CUI”. This identifies and protects sensitive information that do not meet the criteria for “classified” but require safeguarding against unauthorized access.

The "Export Controlled" subcategory encompasses various types of sensitive information, including technical data covering the design, development, production processes, and manufacturing procedures of controlled items. It also includes technology data essential for the production, manufacturing, or consumption of controlled items. The subcategory extends to controlled software source code designed to facilitate the development, manufacture, operation, or servicing of these items. Additionally, items with dual-use technology, subject to export control stipulations, fall under this classification. Moreover, information related to defense services, encompassing technical assistance and training, is also subject to control measures. Protection of such data involves strict adherence to export regulations to prevent unauthorized access or disclosure (National Archives and Records Administration, 2016) .

Business Problem and Proposed Solution

The business problem revolves around the lack of documentation and tracking in the current System Access/Provisioning process, which relies on verbal or email communication. This poses a significant challenge in safeguarding Export Controlled Unclassified Information (CUI). To address this, the proposed solutions involve creating a comprehensive system that logs and digitizes the entire process, implementing robust access controls aligned with NIST and CUI standards. This digitization effort aims to enhance security by incorporating strong user authentication, role-based access, data encryption, and physical security measures. The proposed solution will aid in ascertaining controlled and approved system access, ensuring adherence to NIST standards for compliance. The project's main objectives include securing data access, obtaining stakeholder approvals, defining user access control policies, and establishing two-way communication between GoldenIS and ICP for effective information management and compliance assurance.

Project Goals, Business Outcomes and Objectives

No	Goals	Objectives	Business Outcomes
1	Blueprint to digitized access control system is finalized	GoldenIS is able to communicate without manual email sending back and forth due to digitized system logging communication	Efficiency of communication process is optimized saving GoldenIS and ICP many business hours
2	NIST Compliance and CUI standards are followed	Information and communications between GoldenIS and external contacts is safely transported and data is encrypted based on user access to adhere to security standards	Stakeholders approve of the communication process

Project Scope

We are looking to digitize the method of access controls of GoldenIS business affairs by creating a comprehensive system that logs and documents all communications regarding access controls within the organization. This process needs to meet the NIST compliance and CUI standards to ensure the safe transporting of Controlled unclassified information. Based on the organizational hierarchy and access permissions, we will be incorporating role-based access, data encryption, and user authentication controls to ensure data security. We will be going through the Solution Development Life Cycle (SDLC). After requirements gathering, we will be mapping use cases, followed by an as-is and a to-be BPMN diagram, followed by entity-relationship diagrams, and a database mapped out in the planning stage. The final product will establish a simplified communication process based on access control.

Scope Definition

The project deliverable will be a proof-of-concept paper prototype for our client to then proceed with the implementation coding process of the new process. This prototype will be presented to the client for their consideration and will serve as a basis for initiating the subsequent implementation coding phase of the new process. It's important to note that the proof-of-concept paper prototype itself will not involve the generation of actual implementation code; rather, it will provide a visual and conceptual representation for the client to assess and guide the coding process that follows.

Boundaries

Activities In Scope	Activities Out of Scope
1. Focus on design and flow	1. Functional code
2. Static representation	2. Dynamic user experience

The paper output will highlight design and flow, featuring static representations without functional code, restricting dynamic user experiences. Its purpose is to visually guide the conceptualization of interface design.

Milestones

Project Milestone	Description	Expected Date
1. Project Charter Completion and Signing	Drafting and signing Project Charter for official project initiation and alignment.	February 20, 2024
2. Identification of the problem (s)/opportunities	Clear documentation of identified problems and potential opportunities for improvement.	February 25, 2024
3. Requirement Specification and Modeling	Detailed specification and modeling for precise project requirement understanding and implementation.	February 27, 2024
4. Business Process Modeling (As-is and To-be) diagrams	Visual representation of current and future business process workflows and structures.	March 5, 2024
5. Data Modeling & Design of the new IS solution	Structuring and designing the new Information System solution with data models.	March 12, 2024
6. Structural & Behavioral Design of the new IS solution	Designing an in System for architecture and functionality with structural and behavioral aspects.	March 15, 2024
7. Proof-of-Concept Implementation prototype	Developing a prototype to validate and showcase the project concept.	March 19, 2024
8. Implementation and deployment & risk management plan for the new IS solution	Executing IS solution deployment with a plan addressing potential risks.	March 26, 2024
9. Project Presentation	Conveying project details and outcomes in a comprehensive and engaging presentation.	April 9, 2024

Deliverables

The project's deliverables, including the Project Charter, problem identification, requirement specifications, business process models, data modeling, structural and behavioral design, prototype, and implementation plan, will undergo verification and review by Stanley Yim and Michael Leung at GIS. This ensures alignment with project goals and quality standards, enhancing stakeholder confidence in the project's success.

Project Deliverable 1: NIST Compliance and CUI Research Document	
Stakeholder:	Stanley Yim, Michael Leung
Description:	Research document ensuring NIST compliance and Controlled Unclassified Information (CUI) adherence.
Acceptance Criteria:	Comprehensive, accurate research on NIST compliance, CUI adherence, aligning with security protocols, and legal requirements.
Due Date:	February 9, 2024
Project Deliverable 2: Project Charter	
Stakeholder:	Rodin Lozada, Stanley Yim, Michael Leung
Description:	Initiates and aligns stakeholders officially for project objectives and understanding.
Acceptance Criteria:	Complete, clear, aligned with objectives, stakeholder agreement, defined scope, realistic timeline, allocated resources, risk identification, and legal compliance.
Due Date:	February 20, 2024
Project Deliverable 3: Use Case Models and Descriptions	
Stakeholder:	Stanley Yim, Michael Leung
Description:	Graphical use case models illustrate system interactions; accompanying descriptions detail specific scenarios, enhancing functional understanding.
Acceptance Criteria:	Clear, comprehensive use case models with accurate descriptions aligned with project requirements for stakeholder approval.
Due Date:	February 27, 2024
Project Deliverable 4: As-Is and To be BPMN models	
Stakeholder:	Rodin Lozada, Stanley Yim, Michael Leung
Description:	"As-is" illustrates current processes; "To-be" envisions future processes, aiding understanding and facilitating improvement discussions.
Acceptance Criteria:	Clear, complete BPMN models aligned with standards, accurate, relevant, and user-friendly, meeting stakeholder requirements for approval.

Project Deliverable 5: Entity Relationship and Database Schema Design	
Stakeholder:	Rodin Lozada, Stanley Yim, Michael Leung

Description:	Entity Relationship and Database Schema Design
Acceptance Criteria:	Accurate, complete, consistent, aligned, normalized, performance-optimized, scalable, user-friendly, well-documented, feedback-incorporated for stakeholder approval.
Due Date:	March 12, 2024
Project Deliverable 6: Class and Sequence Diagrams	
Stakeholder:	Rodin Lozada, Stanley Yim, Michael Leung
Description:	Class Diagrams show static structure; Sequence Diagrams depict dynamic interactions, aiding system understanding and development.
Acceptance Criteria:	Clear structure, accurate relationships, align with requirements, depict interactions precisely, for user understanding and approval.
Due Date:	March 15, 2024
Project Deliverable 7: Prototype Modules for 2 Use Cases	
Stakeholder:	Stanley Yim, Michael Leung
Description:	Develop prototype modules for two specified use cases, demonstrating core functionalities and validating feasibility for stakeholders.
Acceptance Criteria:	Accurate functionality, user-friendly interface, align with use case requirements, incorporate feedback, within specified timeframe.
Due Date:	March 19, 2024
Project Deliverable 8: Implementation, deployment, risk assessment and mitigation activities	
Stakeholder:	Stanley Yim, Michael Leung
Description:	Execute system deployment, assess and mitigate risks, ensuring smooth implementation and reduced potential challenges.
Acceptance Criteria:	Smooth deployment, assessed risks, mitigation executed, meeting project objectives and stakeholders' satisfaction.
Due Date:	March 26, 2024
Project Deliverable 9: Project Presentation Slide Deck	
Stakeholder:	Rodin Lozada, Stanley Yim, Michael Leung
Description:	Comprehensive visual presentation summarizing project details and outcomes, engaging stakeholders for effective communication and understanding.
Acceptance Criteria:	Clear, relevant, consistent slides engagingly presenting accurate and comprehensive project information for stakeholder understanding and approval.
Due Date:	April 9, 2024

Dependencies

Dependency Description	Critical Date	Contact
Requirements Gathering	February 9, 2024	Michael Leung
Domain Knowledge	February 16, 2024	Stanley Yim
Project Timeline	February 20, 2024	Astha Maskey Tamang
Understanding of Technology Requirements	February 23, 2024	Michael Leung/Matthew Drumonde
NIST and CUI Compliance	March 15, 2024	Rodin Lozada
Information Confidentiality	April 9, 2024	Rodin Lozada

Project Risks, Assumptions, and Constraints***Risks***

Ineffective user account management, insecure configurations, and overreliance on single controls can lead to vulnerabilities and must be countered through stringent procedures, regular security audits, and a defense-in-depth strategy. The lack of regular access reviews may result in unnecessary access privileges, emphasizing the need for periodic reviews. Inadequate physical security measures and a lack of training and awareness among users can also compromise access controls, requiring the implementation of physical security measures and regular security training programs. Overall, a holistic approach involving technical, procedural, and physical controls, coupled with regular assessments and user awareness initiatives, is essential to address the multifaceted risks associated with access controls.

No.	Risk Description	Probability (H/M/L)	Impact (H/M/L)	Risk Management Plan	OPI
1.	Implementation Delays: Challenges or unforeseen complications in switching to a centralized management platform using Microsoft Power Apps could occur, causing a delay in the transition.	M	H	Establish continuous tracking of the project progress, proactive identification of the implementation barriers, the consistent resource allocation and contingency planning.	TMU Capstone Team and Golden Integrated Solutions (GIS)
2	Stakeholder Resistance: The resistance among the stakeholders (companies and administration) to innovations and deployment of new technologies is another vital issue.	H	M	Comprehensive stakeholder engagement strategies, clear communication of project benefits, delivery of training and support, and rapid answers to concerns.	TMU Capstone Team and ICP management
3	Compliance Pitfalls: Inability to achieve compliance with NIST 800-171, CUI, and CMMC standards result in regulatory fines, reputational damage, and loss of business operation.	M	H	Comprehensive compliance reviews, meeting regulations throughout the whole lifetime of the project, regular audits and risk prevention measures that are being used proactively.	TMU Capstone Team and regulatory compliance officers within ICP

Assumptions

The following table lists the items that cannot be proven or demonstrated when this project charter was prepared, but they are taken into account to stabilize the project approach or planning.

No.	Assumptions
1	Assumption that the current process will fit into the new application. Processes may not be clearly defined from ICP, so we may need to rework these processes to be compliant with the application and the standards. Thus, some process assumptions must be considered that are out of the control of our capstone team and client

Constraints

The following table lists the conditional factors within which the project must operate or fit.

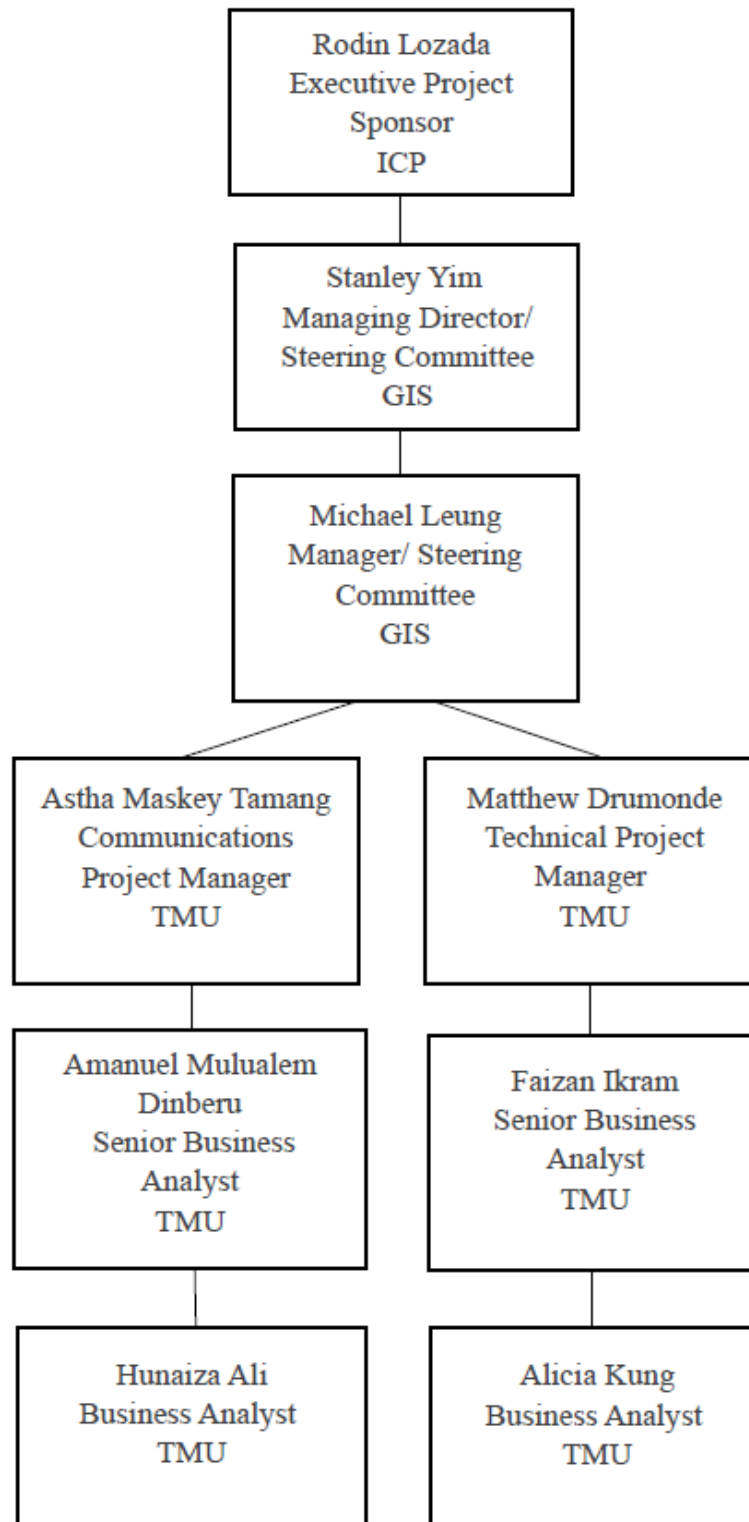
No.	Category	Constraints
1	Scope	The scope constraints creep towards solving a lot more problems that are interrelated with this project. We can deal with this by further defining and clarifying scope with the client.

Project Organization

Project Governance

In the context of access control system design, effective project governance involves a collaborative effort among key roles. The project sponsor, in communication with the managing director, sets the strategic direction by emphasizing the importance of secure access controls. The project manager oversees the day-to-day implementation of access control measures, ensuring alignment with the project's overall goals. The senior business analyst contributes strategic insights into access control requirements, risk analysis, and process improvements. Business analysts play a pivotal role in gathering and analyzing specific access control requirements. The communications manager facilitates transparent communication among stakeholders about the importance and implementation of access controls and deadlines for deliverables. The entire project team, structured with well-defined roles and responsibilities, collaborates to integrate robust access controls into the system design. The project sponsor ensures that access control policies align with organizational objectives, the managing director oversees compliance, and the project manager monitors the implementation of access controls. This collaborative approach ensures a comprehensive and secure access control system design, enhancing the overall governance of the project.

In managing the TMU Capstone project team, each team member is expected to contribute an average of 8-10 hours per week. There is a minimum commitment of 2 hours per person per day, with a maximum of 3 hours per shift. The collective goal is an average of 48 full-time hours per week from the entire group. Regular weekly status reports, including meeting minutes, will be submitted to keep all members informed. Additionally, mid-semester and end-of-semester feedback forms will be requested from the steering committee to assess the team's progress and address any adjustments needed for optimal project performance and client satisfaction. This structure ensures a consistent and accountable approach to managing student involvement, fostering effective communication, and allowing for continuous improvement throughout the project.

Project Team Structure

Roles and Responsibilities

Project Role	Responsibilities	Assigned to
Executive Project Sponsor	<i>provides leadership, resources, and advocacy for project success and alignment.</i>	<i>Rodin Lozada</i>
Managing Director	<i>provides a strategic oversight role, ensuring alignment, resources, and project success.</i>	<i>Stanley Yim</i>
Manager	<i>ensures effective project messaging, stakeholder engagement, and transparent information dissemination.</i>	<i>Michael Leung</i>
Communications Project Manager	<i>plans, executes, and controls, ensuring project success within constraints and goals.</i>	<i>Astha Maskey Tamang</i>
Technical Project Manager	<i>leads and coordinates technical projects, ensuring successful delivery through planning, communication, and team collaboration.</i>	<i>Matthew Drumonde</i>
Senior Business Analyst	<i>leads strategic analysis and requirements and ensures project success, guiding decision-making and fostering collaboration</i>	<i>Amanuel Mulualem Dinberu</i>
Senior Business Analyst	<i>leads strategic analysis and requirements and ensures project success, guiding decision-making and fostering collaboration</i>	<i>Faizan Ikram</i>
Business Analyst	<i>supports senior analysts in research, visualizing requirements, mapping processes, data modeling, UML diagram design, communication, analysis, and decision making.</i>	<i>Alicia Kung</i>
Business Analyst	<i>supports senior analysts in research, visualizing requirements, mapping processes, modeling data, UML diagram design, communication, analysis, and decision making.</i>	<i>Hunaiza Ali</i>

Project Facilities and Resources

The system's success relies on a carefully crafted strategy involving designated facilities, secure office spaces, and testing environments. Special emphasis is placed on the technical proficiency contributed by individuals like Stanley Yim and Michael Leung from GIS. The forthcoming deliverable will underscore the critical role of operating systems, database management systems, development tools, and Microsoft's Identity and Access Management solutions for smooth integration. The personnel aspect is emphasized, detailing the significance of a skilled team within the TMU Capstone group, encompassing roles in project management, research, and business analysis. Tools like Visio, Flowchart Maker, and Online Diagramming Software will be employed for visualizing the system's design. Training programs and comprehensive

documentation are essential for end-user comprehension and system security. The emphasis is also placed on compliance with industry regulations, legal considerations, and seamless integration with Microsoft Power Apps. The student team will construct a simulated SQL database using MySQL server and MySQL Workbench, aimed at assisting the client in tool design. The final deliverable aims to be a pragmatic guide for stakeholders involved in the intricate process of establishing a secure and adaptable access control system within Microsoft Power Apps environments.

Project References

More information concerning this project can be found in the following documents:

Document Title	Version #	Date	Author and Organization	Location (link or path)
Project Charter Guide Template	1D	Jan 26, 2024	Public Services and Procurement Canada	https://www.tpsgc-pwgsc.gc.ca/biens-property/sngp-npms/ti-it/etivcapft-idsfvp-cvc-eng.html
NIST Special Publication 800-171	Revision 2	Jan 26, 2024	Ron Ross, Victoria Pillitteri, Kelley Dempsey, Mark Riddle, and Gary Guissanie	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-171r2.pdf
CUI Category: Export Controlled	32 CFR 2002.16	Jan 26, 2024	ICP	https://www.archives.gov/cui/registry/category-detail/export-control.html
Marking CUI	Version 1.1	February 6, 2024	Information Security Oversight Office - Controlled Unclassified Information	https://www.archives.gov/files/cui/documents/20161206-cui-marking-handbook-v1-1-20190524.pdf
Approval Process Chart	1	February 6, 2024	ICP/GIS	https://drive.google.com/file/d/1GB_rqblBemRxVF6fHcR8YtTJvqrsrzX0/view?usp=drive_link
ICP Organizational Chart	1	February 6, 2024	ICP/GIS	https://drive.google.com/file/d/1ICID9zH_s5xTpvrCgWLelfKmoTneEgOu/view?usp=drive_link

Document Title	Version #	Date	Author and Organization	Location (link or path)
ICP Systems Info.xlsx	1	February 9, 2024	ICP/GIS	https://docs.google.com/spreadsheets/d/1zHD6M3DSnPqQ7ZTBjLrkaCfer8xQGNOo/edit#gid=325614000

Glossary and Acronyms

Term	Definition
NIST	NIST, or the National Institute of Standards and Technology, is a U.S. federal agency that develops and promotes technology, standards, and guidelines to enhance innovation and competitiveness.
Acronym	Name in Full
NIST	National Institute of Standards and Technology
CUI	CUI stands for Controlled Unclassified Information. It refers to unclassified information that requires safeguarding or dissemination controls based on laws, regulations, or government policies.
Acronym	Name in Full
CUI	Controlled Unclassified Information
CMMC	CMMC is a U.S. DoD framework for cybersecurity in defense supply chains, with five maturity levels ensuring compliance and resilience.
Acronym	Name in Full
CMMC	Cybersecurity Maturity Model Certification

1.2 Project Schedule

ITM 900 Toronto Metropolitan University Capstone Project

Group 18



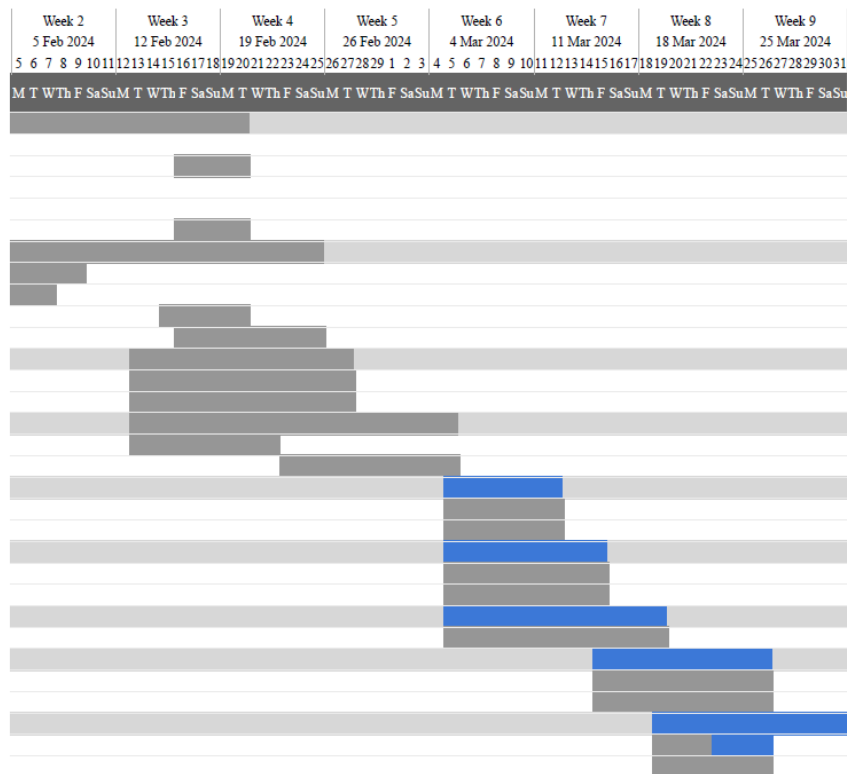
Project Start Date: 1/29/2024 (Monday)

Professor: Arash Saghaei

Client: ICP/GIS

Display Week: 2

WBS [Task [2]	Resources Assigned [3]	Computing Hardware/Software	Start [4]	End [5]	Days [6]	% Done [7]	Work Days [8]
1 Project Management			Fri 1/19/24	Tue 2/20/24	33	100%	23
1.1 Project Charter Drafting	Mathew Drumonde, Ammanuel Muhalem Dinberu, Astha Maskey Tamang	Google Docs	Sat 1/20/24	Fri 2/02/24	14	100%	10
1.2 Project Schedule (Gantt Chart Curation)	Astha Maskey Tamang	Microsoft Excel	Fri 2/16/24	Tue 2/20/24	5	100%	3
1.3 Kick off meeting	Alicia Kung	Microsoft Teams	Fri 1/19/24	Fri 1/19/24	1	100%	1
1.4 Non-Disclosure Agreement Signing	Astha Maskey Tamang	Portable Document Format, Email	Fri 1/26/24	Tue 1/30/24	5	100%	5
1.5 Project Charter Signing	Astha Maskey Tamang	Portable Document Format, Email	Fri 2/16/24	Tue 2/20/24	5	100%	3
2 Identification of the problem (s)/opportunities			Mon 1/29/24	Sun 2/25/24	28	100%	20
2.1 NIST Compliance and CUI Research	Mathew Drumonde, Humaiza Ali, Alicia Kung	Google Docs	Mon 1/29/24	Fri 2/09/24	12	100%	10
2.2 Requirements Gathering for Process Discovery	Alicia Kung	Google Docs	Sat 2/03/24	Wed 2/07/24	5	100%	3
2.3 Overview of the problem(s)/opportunities	Mathew Drumonde	Google Docs	Thu 2/15/24	Tue 2/20/24	6	100%	4
2.4 Diagnostic (causes-problem-consequences)	Mathew Drumonde	Google Docs	Fri 2/16/24	Sun 2/25/24	10	100%	6
3 Requirement Specification and Modeling			Tue 2/13/24	Tue 2/27/24	15	100%	11
3.1 Use Case Modelling	Faizan Ikram, Alicia Kung, Humaiza Ali	Visio, Draw.io	Tue 2/13/24	Tue 2/27/24	15	100%	11
3.2 Use Case Descriptions	Faizan Ikram, Alicia Kung, Humaiza Ali	Visio, Draw.io	Tue 2/13/24	Tue 2/27/24	15	100%	11
4 Business Process Modeling (As-is and To-be) diagrams			Tue 2/13/24	Tue 3/05/24	22	100%	16
4.1 BPMN Model Diagrams (As-is)	Astha Maskey Tamang, Mathew Drumonde, Alicia Kung	bpmn.io	Tue 2/13/24	Thu 2/22/24	10	100%	8
4.2 BPMN Model Diagrams (To-be)	Astha Maskey Tamang, Mathew Drumonde, Alicia Kung	bpmn.io	Fri 2/23/24	Tue 3/05/24	12	100%	8
5 Data Modeling & Design of the new IS solution			Tue 3/05/24	Tue 3/12/24	8		6
5.1 Entity Relationship Diagram Design	Ammanuel Muhalem Dinberu, Faizan Ikram, Humaiza Ali	Visio, Draw.io, Lucid Chart	Tue 3/05/24	Tue 3/12/24	8	100%	6
5.2 Database Schema Design	Ammanuel Muhalem Dinberu, Faizan Ikram, Humaiza Ali	Visio, Draw.io, Lucid Chart	Tue 3/05/24	Tue 3/12/24	8	100%	6
6 Structural & Behavioral Design of the new IS solution			Tue 3/05/24	Fri 3/15/24	11		9
6.1 Class Diagram	Mathew Drumonde, Alicia Kung	Visio, Draw.io	Tue 3/05/24	Fri 3/15/24	11	100%	9
6.2 Sequence diagrams (one per use case)	Faizan Ikram, Mathew Drumonde, Ammanuel Muhalem Dinberu, Alicia Kung	Visio, Draw.io	Tue 3/05/24	Fri 3/15/24	11	100%	9
7 Proof-of-Concept Implementation prototype			Tue 3/05/24	Tue 3/19/24	15		11
7.1 Prototype modules	Ammanuel Muhalem Dinberu, Mathew Drumonde, Astha Maskey Tamang, Alicia Kung	MySQL Workbench	Tue 3/05/24	Tue 3/19/24	15	100%	11
8 Implementation and deployment & risk management plan for the new IS solution			Fri 3/15/24	Tue 3/26/24	12		8
8.1 Implementation and deployment activities	Mathew Drumonde, Astha Maskey Tamang	Google Docs	Fri 3/15/24	Tue 3/26/24	12	100%	8
8.2 Risk assessment and mitigation activities	Mathew Drumonde, Astha Maskey Tamang	Google Docs	Fri 3/15/24	Tue 3/26/24	12	100%	8
9 Project Presentation			Tue 3/19/24	Tue 4/09/24	22		16
9.1 Presentation Slide Deck Construction	Alicia Kung, Humaiza Ali, Astha Maskey Tamang	Powerpoint, Canva	Tue 3/19/24	Tue 3/26/24	8	50%	6
9.2 Prototype Demo	Astha Maskey Tamang, Mathew Drumonde, Ammanuel Muhalem Dinberu, Alicia Kung	MySQL Workbench	Tue 3/19/24	Tue 3/26/24	8	100%	6
9.3 Oral Presentation (15 minutes)	Everyone	Powerpoint, Canva	Tue 4/09/24	Tue 4/09/24	1	0%	1



2. Identification of the problems and opportunities



Access Controls Management System
Business Projects-IT-Enabled
Requirements Gathering Phase

2.1 Overview of the problem(s)/opportunities

The System Access/Provisioning process at International Custom Products (ICP) is inefficient and has security vulnerabilities. Here are the identified problems and opportunities:

Problems

Inefficiency and Absence of Documentation: The lack of centralization in this system makes it difficult to track requests for access since they can only be communicated orally or through emails. This situation creates inefficiencies while also making it hard to document the request for accessing services. It is thus prone to a high risk of Export Controlled Unclassified Information (CUI).

Lack of Security: By not establishing a total system solution, ICP lays itself open to security threats that can lead to reputation damage.. Consequently, without proper documentation and traceability, maintaining adherence to security standards like NIST 800-171 and CMMC framework poses difficulties.

Manual Approval Procedures: Manual approval methods contribute to inefficiencies as well as increasing error chances or oversights. Automating these processes would enhance efficiency within the organization's overall operations.

No Conformance: Security controls on the current system have significant gaps that do not ensure regulatory compliance. Thus, this exposes confidential data to grave risks which might further lead into non-compliance penalties.

Opportunities

Automation: There's an opportunity to automate approval processes, maintain access logs and improve overall efficiency by implementing a centralized management platform, perhaps with Microsoft Power Apps. Use of automation can make access provisioning faster and more accurate while reducing manual effort.

Enhanced Security Measures: Compliance with NIST and CUI standards through the introduction of advanced access controls will help ICP enhance data protection and mitigate security risks. This would also ensure traceability and documentation in order that compliance with security standards is more effective through implementation of an all-inclusive system solution.

Streamlined Processes: Reducing delays in System Access/Provisioning process improving the experience of users is one way this project can streamline its activities. These steps will promote effectiveness as well as efficiency since management is centralized and procedures are standardized.

The enhanced compliance: ICP's enforcement of efficient access controls and compliance mechanisms can guarantee adherence to regulations. This is responsible for the elimination of risks associated with non-compliance fines as well as enhancing security's and reliability organizational reputation.

Therefore, addressing the said problems offer a chance to ICP to improve its operational efficiency, tighten its security measures and meet industry standards. Through technology and effective processes, sensitive information within ICP can be secured and the organization runs efficiently.

2.2 Diagnostic (causes-problem-consequences)

Causes

Decentralized Systems: ICP's decentralization of systems currently causes inefficiency and presents a problem in managing access requests. The challenge is worsened by lack of a centralized management platform to keep up documentation or ensure security standard compliance.

Inefficient Communication: Oral or email-based communication for the provisioning process delays, errors, and lack of traceability. This kind of inefficient communication makes it impossible to effectively manage access requests and puts export controlled unclassified information (CUI) at risk.

Lack of Automation: Absence of automated approval and access control procedures further complicates matters for ICP. Manual approval processes only slow down operations but also raise chances of making mistakes as well as inconsistencies during the provision of accesses.

Problems

Ineffective System Access Process: The decentralized systems, inefficient communication methods and no automation make the current System Access/Provisioning process at ICP ineffective. Consequently, this leads to delays, inaccuracies and exposure to security threats which would compromise the confidentiality and integrity of sensitive information such as CUI.

Compliance Challenges: Compliance with NIST 800-171 and the CMMC framework is difficult due to how decentralized the current systems are, and the lack of any documentation. Failure to follow these standards will put a company at risk for fines from regulators and will also harm their reputation as reliable vendors for institutional, government, and defense contractor entities.

Consequences:

Operational Inefficiencies: The system access/provisioning process experiences inefficiencies causing delays in granting access leading to reduced productivity and possible disgruntled employees as well. Operational efficiency is further compromised by having manual procedures that require more time and resources to manage.

Security Risks: The decentralization of management functions, lack of maintenance records, together with inefficient communication processes have enhanced security threats such as data breaches. The aftermath of failing to effectively safeguard CUI can be grievous including legal implications, financial liabilities among others alongside corporate image ruin.

Compliance Issues: In the event that security requirements such as NIST 800-171 and CMMC are not adhered to, penalties will be levied by the regulatory bodies on non-compliant companies which may also lead to loss of business opportunities. It can also erode confidence from clients and partners who depend on ICP's commitment to secure their information through strict safety measures.

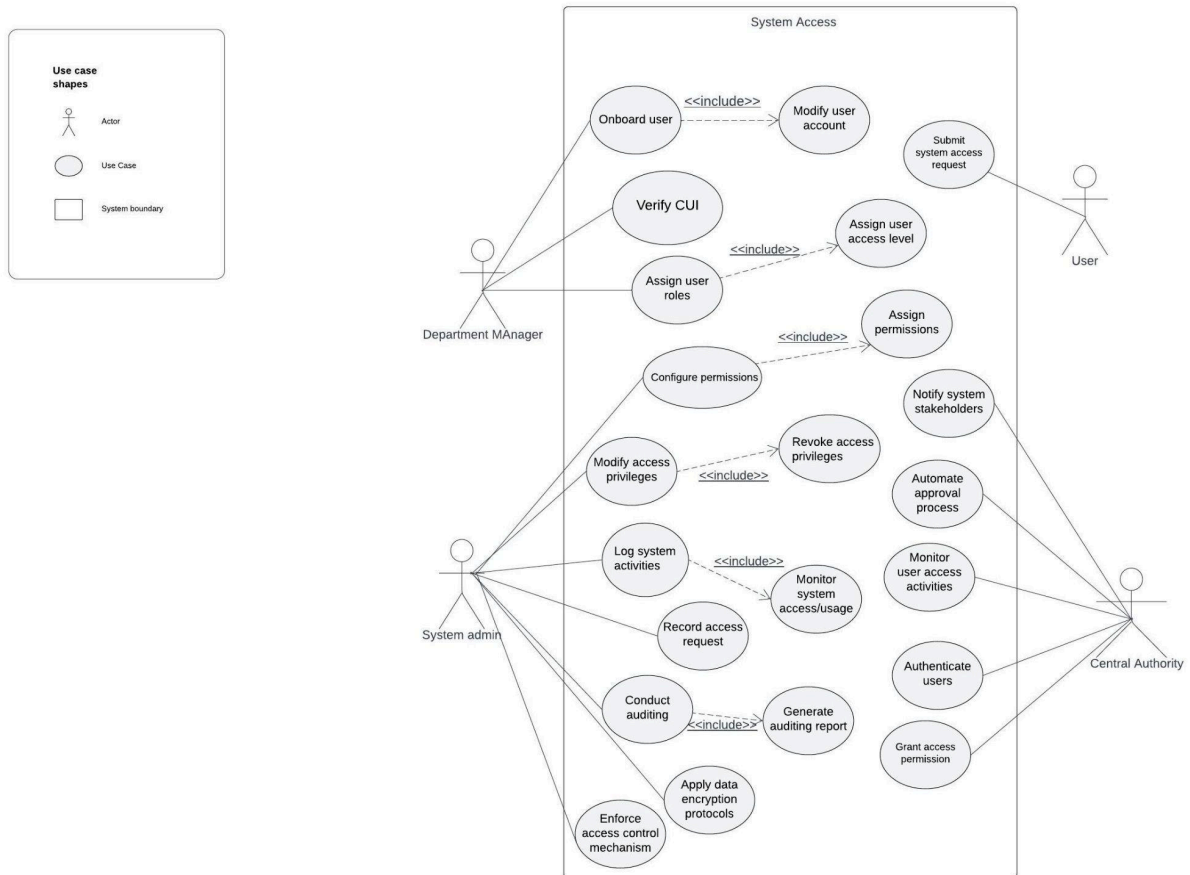
To sum up, ICP's problems have been caused by decentralized systems, ineffective communication and no automation of access provision. These problems result in inefficiencies in operations, security vulnerabilities and issues related to compliance that finally affect the company's productivity, reputation, and ability in securing delicate information satisfactorily.

3. Requirement Specification & Modeling



Access Controls Management System
Business Projects-IT-Enabled
Use Case Modeling Phase

3.1. Use Case Model



3.2 Fully developed use case descriptions

Use case 1: System access approval request

Use case name:	Request system access permission/approval	
Scenario:	User initiates request for system access approval to acquire necessary permissions to access CUI data.	
Triggering event:	User needs permission and approval from department managers to gain access to the system that needs to be compliant with NIST compliance and CUI.	
Brief Description:	A user initiates a request for system access approval to obtain the required permissions to access CUI data. The process ensures alignment with NIST Protocols and organizational policies governing access to CUI data. Upon approval, the user is granted the necessary permissions to access the designated system or application and handle CUI data in accordance with established guidelines.	
Actors:	Requester/ System user	
Stakeholders:	User, Department Managers, Compliance Team, External service providers, and Centralized Authority (Rodin and Marc).	
Preconditions:	1. Users needs to have required credentials for requested system access permission 2. System authentication process conforms to NIST 3. Active directory is configured for automatic user data access and granting system access control	
Postconditions:	1. User obtains system access permission/approval 2. System access request is archived and closed	
Flow of Activities:	Actor	System

	1. User initiates system access request by selecting specific system 1, 2, 3, or 4. User enters credentials and required authentication details. 2. User receives system access approval permission.	1.1 System authenticates user data. 1.2 System verifies system access control policies. 1.3 Central Authority figure grants access 1.4 Department manager shares access and sends access approval notification.
Exception Conditions:	1.1 Invalid user credentials. 2.1 Automatic system verification process is not responsive. 3.1 Delay in approval decision from Centralized Authority (Rodin and Mark). Issues with assessing CUI by department managers.	

Use case 2: User Onboarding

Use case name:	User Onboarding
Scenario:	New users are prompted to create valid credentials to be inputted into the provisioning system. System onboards new user and assigns them with proper department role and system privileges.
Triggering event:	The onboarding team or manager initiates the onboarding process in the system, triggering the creation of a user profile for the new employee. User Initiation
Brief Description:	☐ Create user profiles and assign initial access rights based on job roles and responsibilities. ☐ Document user credentials, training completion, and security clearances.
Actors:	Department Manager

Stakeholders:	System Administrator, Department Manager, Department Teams, New User	
Preconditions:	- New User Profile Creation - Assignment of access control policies and role specifications	
Postconditions:	- User profile created - Assignment of access control policies has been deemed successful - Approval of assigned access is confirmed by new user's department manager	
Flow of Activities:	Actor	System
	1. User provides personal information, username, password, first name and last name 2. New User verifies email 3. New User completes onboarding training of system provisioning	1.1 System creates user profile for new user 1.2 System generates and assigns access control assignments for new user 1.3 System alerts User with email of specifics including assignment and login credentials 2.1 System is alerted of User's agreement to assigned control policies 2.2 System assigns basic user training 3.1 System recognizes completion of user onboarding
Exception Conditions:	1.1 Invalid User Profile 2.1 System resources are down or currently out-of-service 3.1 Policy Violations or overlap 4.1 Manager approval delay 5.1 Security Incidents 6.1 Incomplete User Training	

Use case 3: User Authentication Workflow

Use case name:	User Authentication Workflow
Scenario:	Before a user can access the system, they must be authenticated and be given certain roles

Triggering event:	User authenticating new credentials within the database	
Brief Description:	Authenticating new users into the database, making sure security and authentication protocols are followed	
Actors:	User, Manager/Supervisor, System Administrator	
Stakeholders:	Users, Developers, Security, System Administrator, Compliance Officers, Manager/Supervisor, Auditor, Support Staff	
Preconditions:	- If User is employee, must be Onboarded - System infrastructure must adhere to compliance requirements - Authentication policies must be established	
Postconditions:	- User is successfully authenticated - Security Measures are put in place - Compliance with regulations - Process is Documented and Reported	
Flow of Activities:	Actor	System
	1. 2. System Administrator reviews request 3. System Administrator accept the request 4. System Administrator provides authentication to the user 5. User Initiates access attempt 6. User Interacts with the system 7. User initiates session termination	1.1 System Generates Request 1.2 2.1 NA 2.2 3.1 System enters users credentials 3.2 4.1 System authenticates user credentials 5.1 System requests credentials 5.2 Provides access to user 5.3 If credentials invalid, denys access 6.1 System monitors user activity 7.1 System terminates user session 7.2 System logs any authentication related events

Exception Conditions:	1.1 Invalid Credentials 2.1 Account lockout from failed user log in 3.1 Compliance Violations
-----------------------	---

Use case 4: Audit Reporting

Use case name:	Audit Reporting
Scenario:	Documenting all actions within the system towards an audit log
Triggering event:	Any and all action within the system
Brief Description:	☐ Maintain a comprehensive log of all access-related activities, including user logins, access modifications, and policy violations. ☐ Generate reports for internal audits, compliance assessments, and security incident investigations.
Actors:	System Administrator, Department Manager, Internal Auditor, Compliance Team
Stakeholders:	Board of directors, data owners, compliance teams, internal audit teams, external regulatory agencies, executive managers, system administrator, third-party service providers, affected user, public relations and communications teams.
Preconditions:	1. Users must have a valid authenticated account within the system 2. Compliance requirements must be met in accordance to NIST and CUI 3. User Account actions are taken place within the system in accordance to Data Integrity 4. Internal Auditing team must have access within the system, with regards to data sensitivity
Postconditions:	1. User actions to be documented within internal audit log 2. Audit logs accessible within corresponding teams 3. Data Integrity and sensitivity to be upheld with regards to CUI 4. Stakeholders review logs to address any gaps with regards to compliance

	5. As needed, managerial teams review internal audit logs to assess the team.	
Flow of Activities:	Actor	System
	1. System Admin / Internal Auditing team receives alerts within auditing log 2. System Admin / Internal Auditing team reviews alert	1.1 System logs user action 1.2 System organizes documentation and alerts corresponding team lead 2.1 System reveals exactly what actions took place, with corresponding details such as data compliance detail and action time
Exception Conditions:	1.1 Technical Issues with Data logging within Audit log 2.1 Failing to adhere to the required reporting standards, such as format, content, or timing requirements. 3.1 Lack of meaningful analysis or context	

Use case 5: Unauthorized User Access Response

Use case name:	Respond to unauthorized access.
Scenario:	Respond to unauthorized user access.
Triggering event:	An unauthorized user attempts to access the system or CUI data without proper authorization.
Brief Description:	An unauthorized user, who lacks the necessary permissions or credentials, deliberately tries to gain access to the system or sensitive CUI data. The system administrator responds to unauthorized access by performing a series of actions on the automated system.
Actors:	System administrator
Stakeholders:	Board of directors, data owners, compliance teams, internal audit teams, external regulatory agencies, executive managers, system administrator, third-party service providers, affected user, public relations and communications teams.

Preconditions:	1. Users must be an unauthorized individual who doesn't have required credentials to gain access to the system and CUI data. 2. The system are accessible by authorized personnel to detect and respond to unauthorized access attempts. 3. Intrusion detection systems (IDS), security information and event management (SIEM) systems, and access logs must be actively monitoring the system for unauthorized access attempts. 4. Relevant security controls and mechanisms are enabled. 5. An incident response plan outlining the procedures for responding to unauthorized access is established and accessible to relevant personnel. 6. Communication channels for notifying stakeholders need to be activated. 7. Tools for reporting incidents must be accessible to facilitate incident response and compliance reporting.	
Postconditions:	1. The unauthorized access attempt is successfully contained. 2. Any changes caused by the unauthorized access are identified and remediated. 3. Security controls and mechanisms are strengthened and aligned with NIST 800-171. 4. Detailed documentation of the unauthorized access incident 5. Stakeholders are notified regarding the unauthorized access as per organizational policies and NIST compliance. 6. A post-incident analysis is conducted to understand the cause of the unauthorized access and identify any gaps in security controls. 7. Ongoing monitoring of systems and CUI data is established to detect and respond to any future unauthorized access.	
Flow of Activities:	Actor	System
	1. System administrator receives an alert regarding the unauthorized access attempt and requests the incident tickets. 2. System administrator invokes incident response measurements.	1.1 System logs the incident. 1.2 System generates incident tickets. 2.1 System isolates the affected systems. 2.2 System revokes access credentials 2.3 System disables compromised user accounts. 3.1 System generates system logs and network traffic data.

	3. System administrator initiates an investigation and gathers relevant evidence. 4. System administrator invokes remediation measurements. 5. System administrator modifies the incident records concerning the response measurements taken and critical information from the investigation.	3.2 System identifies the security vulnerabilities and root cause of the incident. 3.3 System generates detailed incident reports. 4.1 System enhances security patches. 4.2 System updates system access controls. 4.3 System strengthens user authentication mechanisms. 5.1 System updates incident records. 5.2 System achieves the documents. 5.3 System closes the incident case.
Exception Conditions:	1.1 Lack of access permissions 1.2 Incident tickets for the same unauthorized access incident are duplicated redundantly. 2.2 Lack of approval to revoke the access credentials. 2.3 Legal or regulatory constraints 3.2 Limitations in vulnerability assessment tools, bugs, and Lack of available patches for identified vulnerabilities. 3.3 Access restrictions, data privacy regulations, and contractual limitations. 4.1 Changes in data protection laws, security policies, or contractual agreements with external parties. 4.2 Software bugs and deployment issues. 4.3 Lack of Compatibility with external software and hardware. 5.1 Write access restriction and inconsistent data. 5.2 File access restrictions. 5.3 Incomplete investigation, inconsistent data, unavailability of external experts , third-party reporting errors, legal and regulatory hold	

Use case 6: User Access Revocation

Use case name:	User Access Revocation	
Scenario:	When a user leaves an organization, has a change in responsibilities or their contract expires the specific access they have to the database is revoked	
Triggering event:	User Termination	
Brief Description:	Revoking a user's access within the organization's infrastructure once the request has been identified. Implementing any communication and security process along the way	
Actors:	User, Manager/Supervisor/Director, IT Administrator,	
Stakeholders:	User, Manager/Supervisor/Director, Human Resource Personnel, Auditor, Compliance Officers,	
Preconditions:	- Identify User - Verify Request	
Postconditions:	- User Access Revoked - Documentation Updated - Notification Sent - Closure of Revocation Process	
Flow of Activities:	Actor	System
	1. Manager initiates the revocation process 2. IT Administrator identifies the request 3. IT Administrator reviews the request 4. IT Administrator documents the request 5. IT Administrator executes the request	1.1 System receives request for revoking a users access 1.2 2.1 System identifies user accounts based off the request 2.2 3.1 System reviews request and information about user 3.2 4.1 Details about the request and the user is documented by the system 4.2

	6. User is Notified 7. The Request is closed	5.1 System executes the request and terminates users access 5.2 6.1 Notification is sent to the user about access revocation 6.2 7.1. The request process is marked as closed
Exception Conditions:	1.1 Unauthorized Revocation Request without proper authorization or approval 2.1 User not found 3.1 Inaccurate Documentation 4.1 Technical Errors 5.1 Partial Revocation	

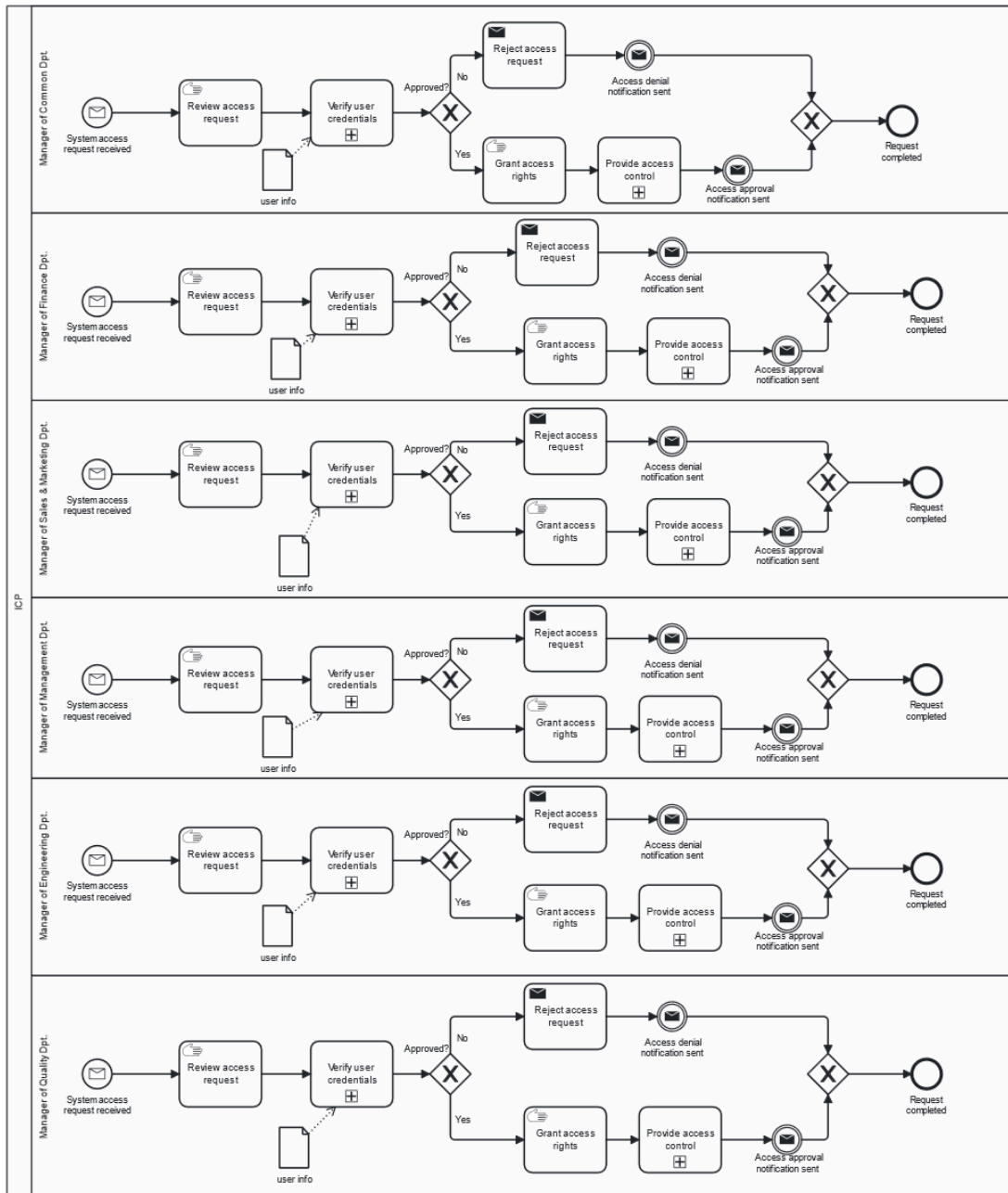
4. Business Process Modeling (As-is and To-be diagrams)



Access Controls Management System
Business Projects-IT-Enabled
Business Process Modeling Phase

4.1 BPMN Model Diagrams

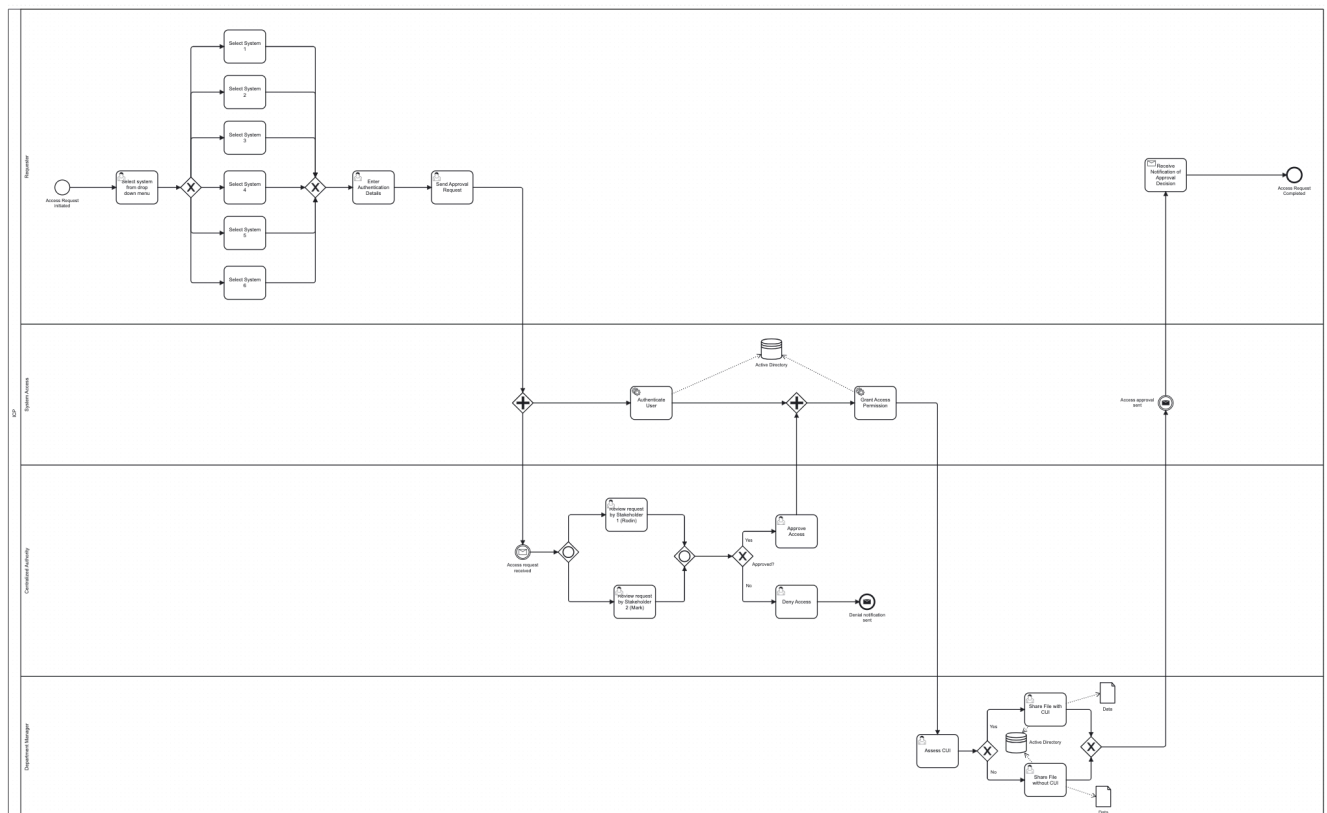
BPMN As-Is: Each department manager receives system access requests by emails from the requester within ICP. The manager reviews system access requests and verifies user credentials and decides if the request should be rejected or granted with access rights. If the access request is denied, then the manager sends an access denial email to the requester. If the access request is approved, the access rights are granted and the access control is provided by the manager. Lastly, the system access approval email is sent to the requester to notify the approval. The request is completed.



BPMN Design

The system access approval process initiates with requesters triggering the procedure and selecting a desired system from a dropdown menu. Two sequential stakeholder reviews, the Initial Stakeholder Review (Rodin) and Secondary Stakeholder Review (Marc), follow. The Access Approval Path, at the second exclusive gateway, diverges based on evaluations during the stakeholder reviews, categorizing requests as "File Sharing with CUI" or "File Sharing without CUI." Access Authorization then utilizes decision-making mechanisms to identify requesters and their unique identifiers in the active directory, with approval from the administrator based on identity and divisional criteria. Authorization by the Administrator/Department Manager occurs, considering cumulative stakeholder review outcomes. A Send Task, using Power Apps, sends an email notification to the approved user, marking the completion of the process at the End Event.

BPMN To-Be



5. Data Modeling & Design of the new IS solution



Access Controls Management System
Business Projects-IT-Enabled
Data Modeling Phase

5.1. Entity Relationship Diagram

In our business solution, several key entities play crucial roles in managing access requests and file sharing. These entities comprise Requesters, Central Authority Figures, Department Managers, Systems, Access Requests, and File Shares. Requesters, distinguished by a unique RequesterID, can initiate multiple access requests, each associated with specific systems and tracked through a RequestID. Central Authority Figures, identified by an AuthorityID, possess the authority to approve or deny access requests, establishing a one-to-zero or more relationship with access requests. Department Managers, characterized by a ManagerID, oversee multiple file shares, each with its unique ShareID, establishing a one-to-zero or more relationship between managers and shares. Systems, identified by SystemID, are described in detail within our solution. File Shares, each possessing a unique ShareID, are characterized by a ShareName and managed by Department Managers. This structured framework ensures efficient access control and file management within the organization.

An Entity-Relationship Diagram (ERD) for a system featuring a requester, authentication, central authority figures approval, and file share access oversight by a department manager can be outlined with entities, attributes, and relationships as follows:

Entities:

Requester: Attributes: RequesterID (Primary Key), Username, Password, FirstName, LastName, EmailAddress, and other pertinent details.

Central Authority Figure: Attributes: AuthorityID (Primary Key), Username, Password, FirstName, LastName, and other relevant information.

Department Manager: Attributes: ManagerID (Primary Key), Username, Password, FirstName, LastName, and other necessary particulars.

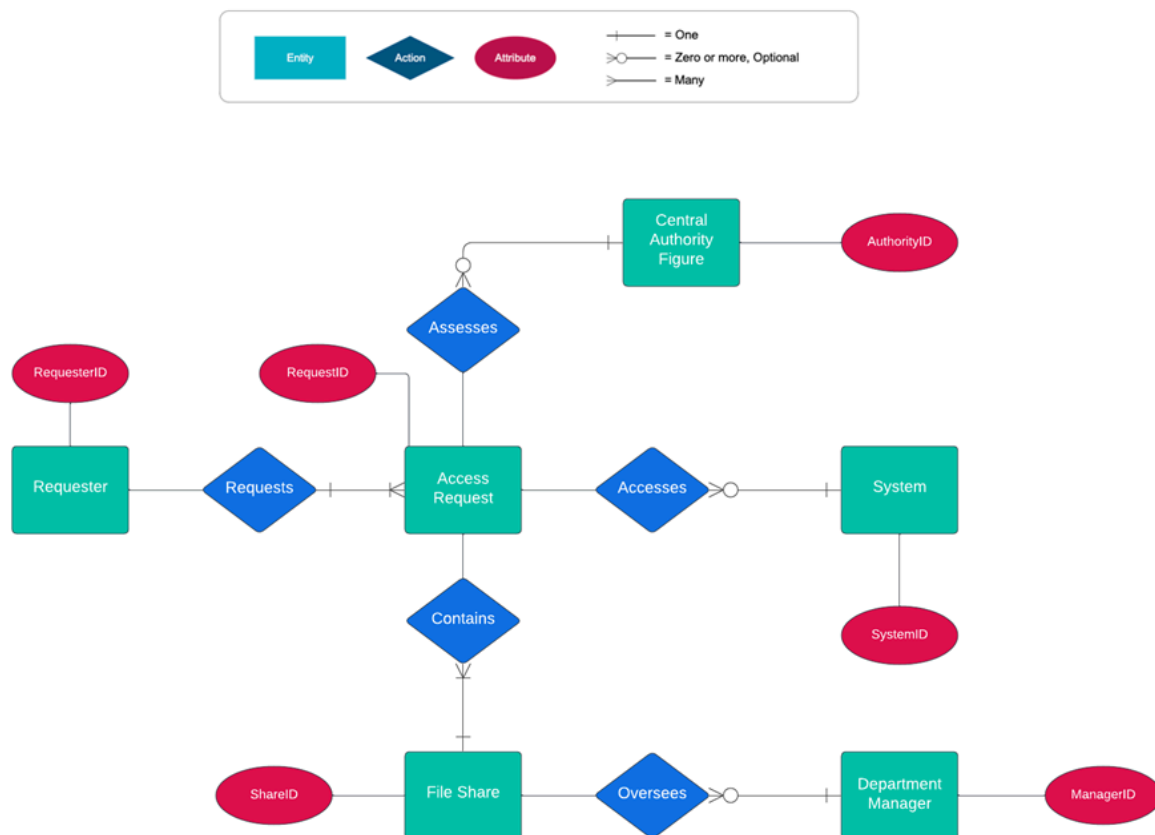
System: Attributes: SystemID (Primary Key), SystemName, Description, and other relevant details.

Access Request: Attributes: RequestID (Primary Key), RequestDate, Status (Pending, Approved, Denied), RequesterID (Foreign Key), AuthorityID (Foreign Key), SystemID (Foreign Key), ShareID (Foreign Key), RequestNumber, and other pertinent attributes.

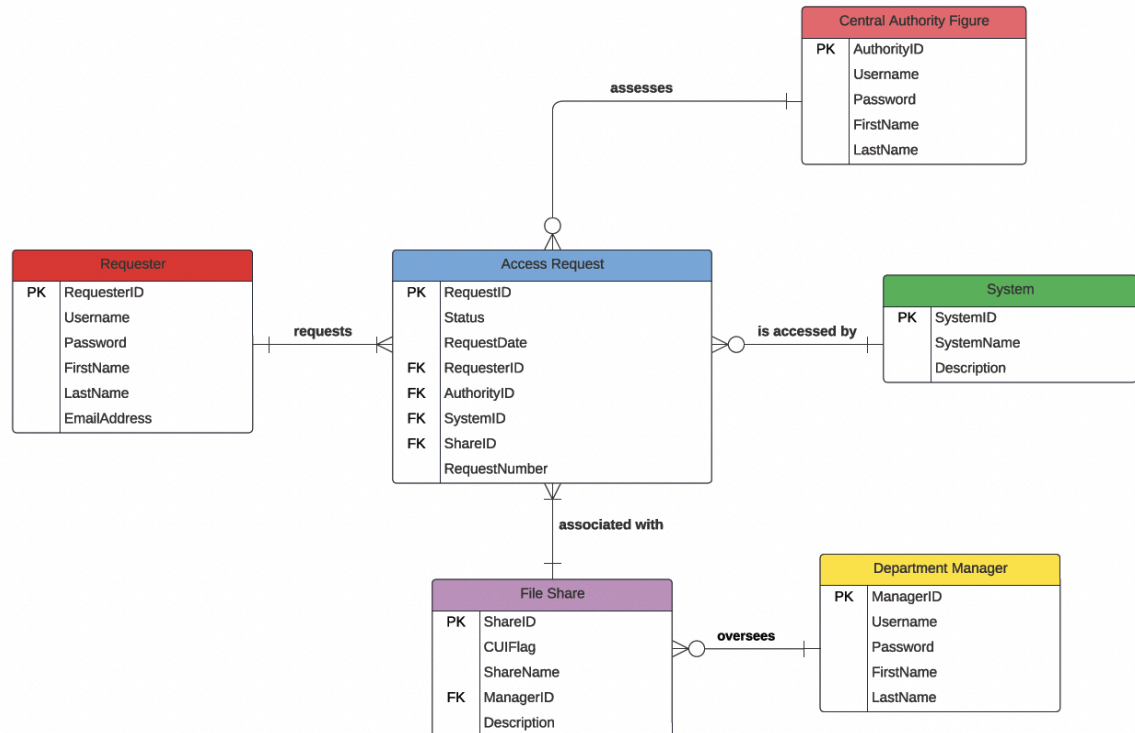
File Share: Attributes: ShareID (Primary Key), ShareName, Description, ManagerID (Foreign Key), CUI (Controlled Unclassified Information) Flag, and other pertinent information.

Relationships:

- A Requester has the ability to generate multiple Access Requests (One-to-Many relationship).
- Each Access Request is linked to one System and one Requester (Zero or More-to-One relationship with System and Requester).
- A Central Authority Figure holds the authority to approve or deny multiple Access Requests (One-to-Zero or More relationship).
- Each Access Request is associated with one Central Authority Figure for approval (Zero or More-to-One relationship with Central Authority Figure).
- A Department Manager is responsible for overseeing multiple File Shares (One-to-Zero or More relationship).
- Each File Share is managed by one Department Manager (Zero or More-to-One relationship with Department Manager).



5.2. Database schema



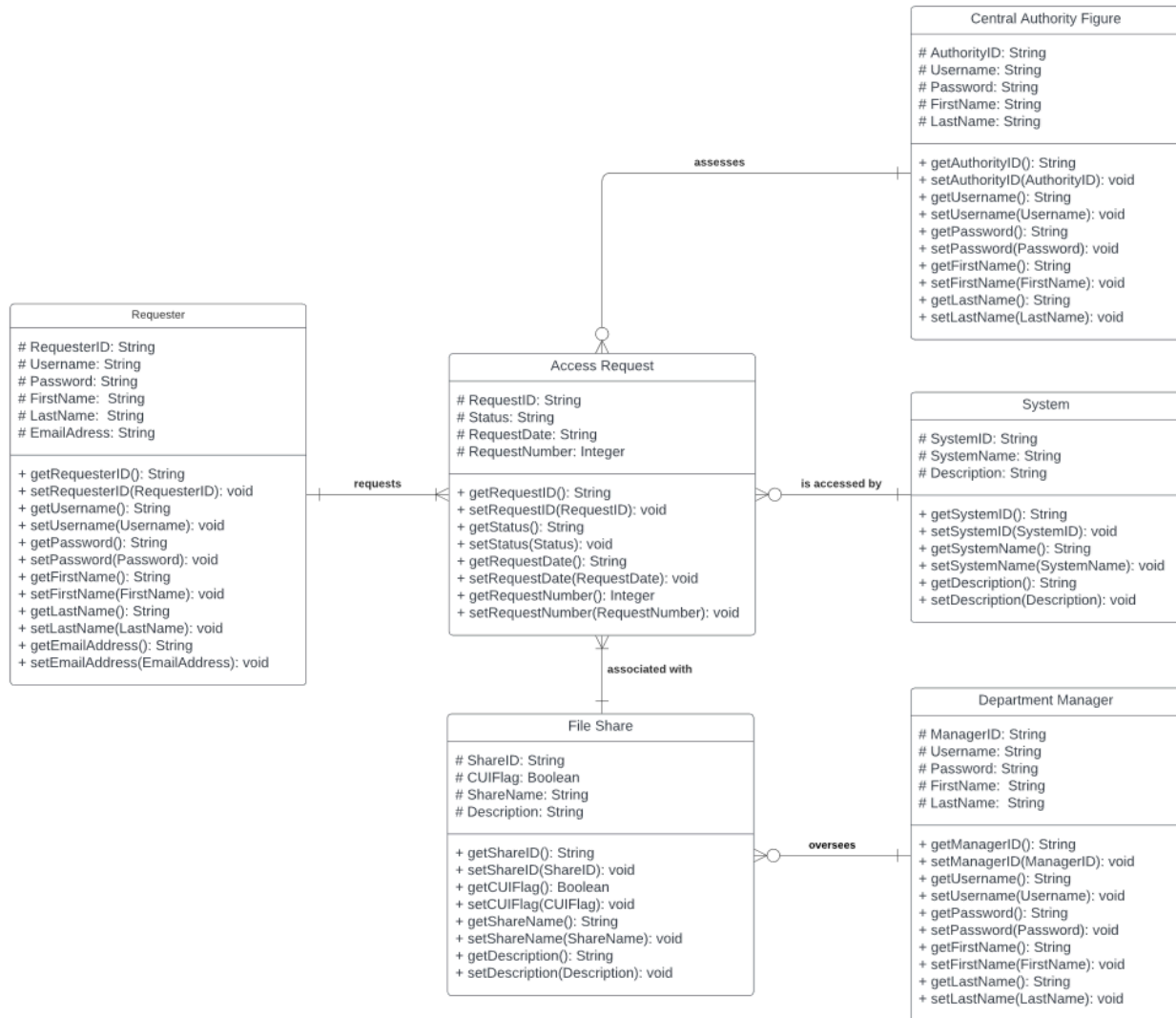
In this Database schema, it is being shown what is being done in an Access Request use case. The relationships between each entity, the type of relationships and what foreign keys are linked to one another are defined.

6. Structural & Behavioral Design of the new IS solution



**Access Controls Management System
Business Projects-IT-Enabled
Solution Design Phase**

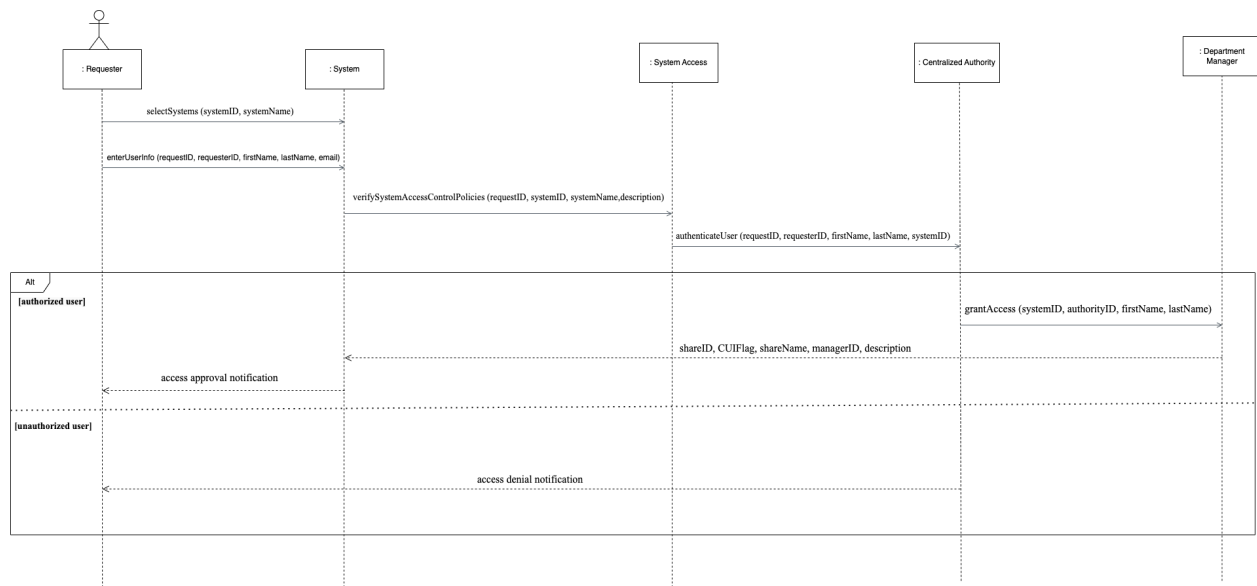
6.1. Class Diagram



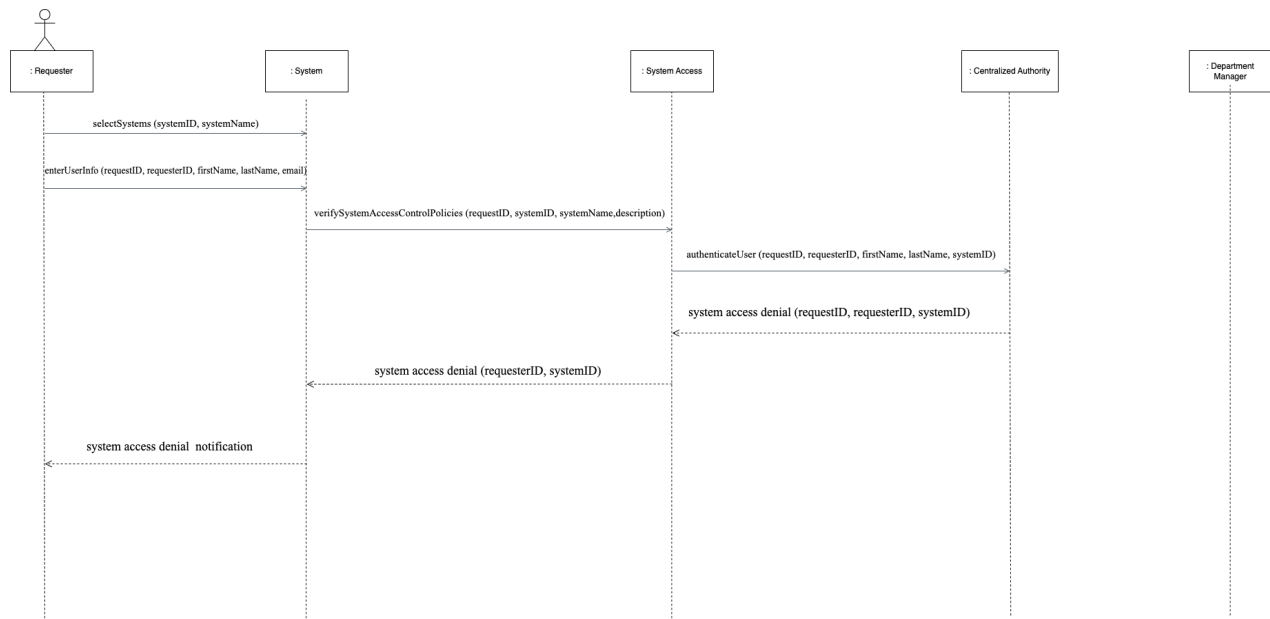
The class diagram for an Access Approval use case illustrates classes such as Requester, AccessRequest, Department Manager, Central Authority Figure and File Share, depicting their attributes and relationships. Methods for requesting access, approving requests, and managing users are outlined. Access control mechanisms are implemented to regulate permission levels and ensure security.

6.2. *Sequence diagrams*

System Access Approval: A requester selects the requested system and enters user info, including request ID, requester ID, first name, last name, and email. The system verifies System Access Control Policies. Once it's done, the centralized authority authenticates the requester. If the requester has authorization to access the requested system, the centralized authority grants system access before the Department Manager verifies CUI and returns shareID, CUIFlag, share name, manager ID, and description. Lastly, the system sends an access approval email. If the requester is an unauthorized user, the system sends an access denial notification to the requester.



Unauthorized User request: A requester selects requested systems and enters user info. The system access verifies system access control policies based on the input info of the request ID, system ID, system name, and description. A centralized authority authenticates the requester and returns system access denial to the system. Lastly, the system sends a system access denial email to the unauthorized requester.



7. Proof-of-Concept Implementation prototype



Access Controls Management System
Business Projects-IT-Enabled
Implementation Phase

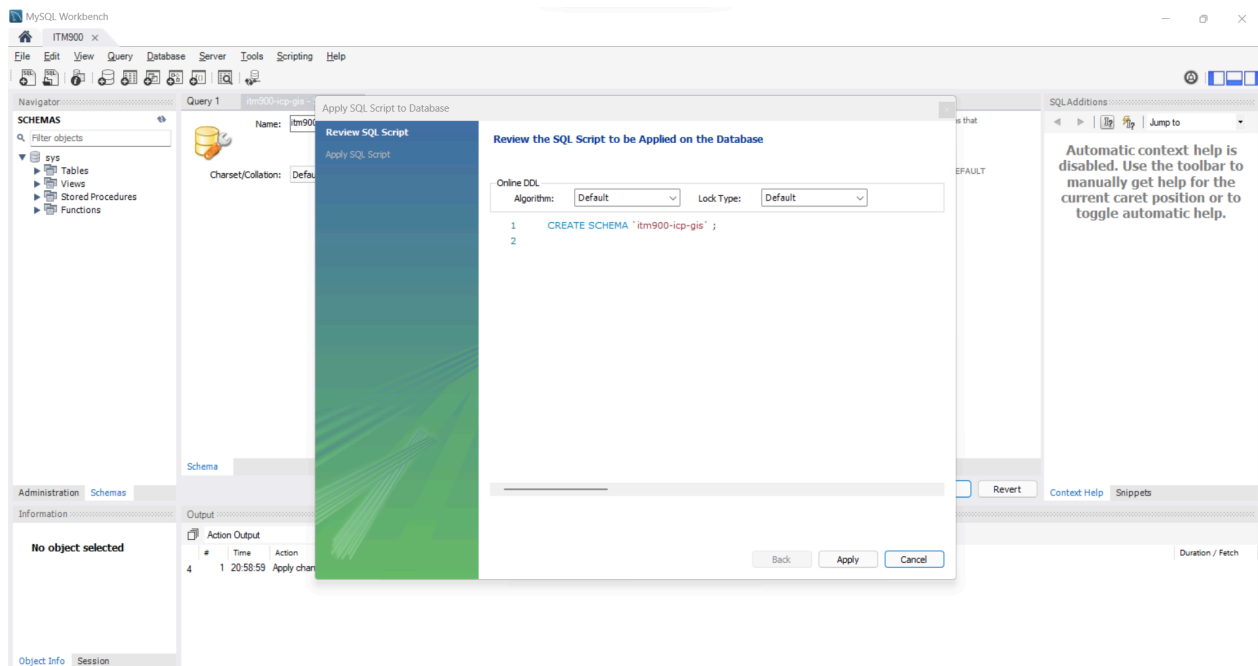
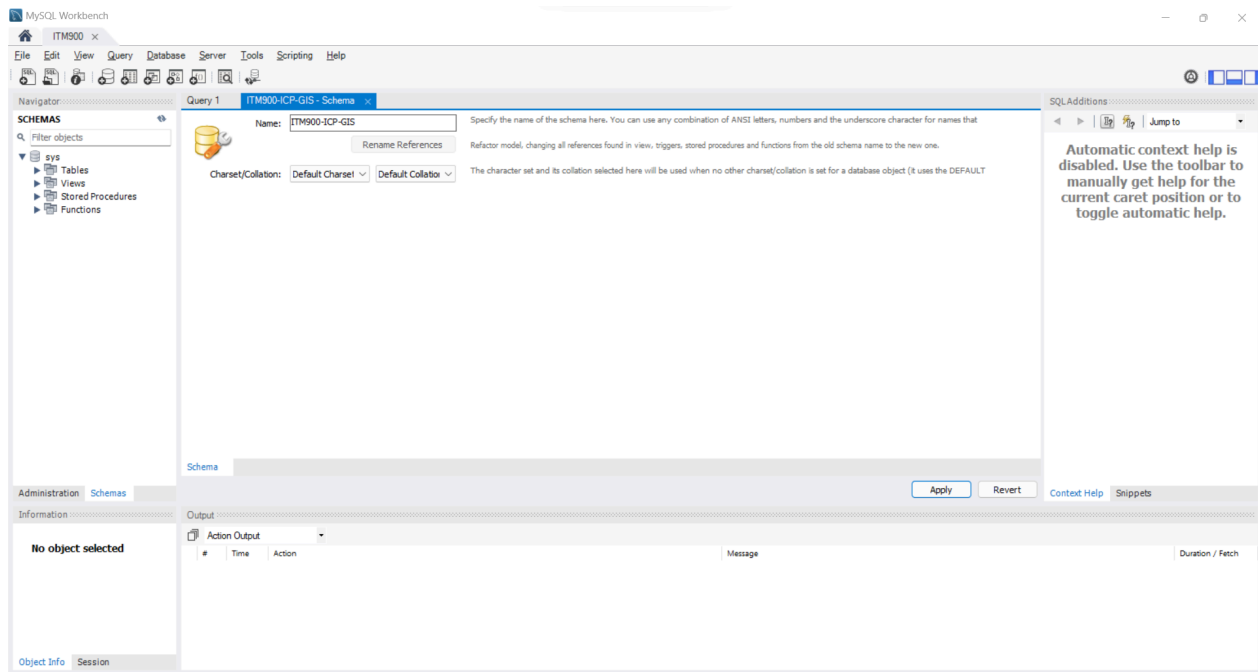
7.1 Prototype Modules

SQL Database Code

-- Create Schema

Creating the database

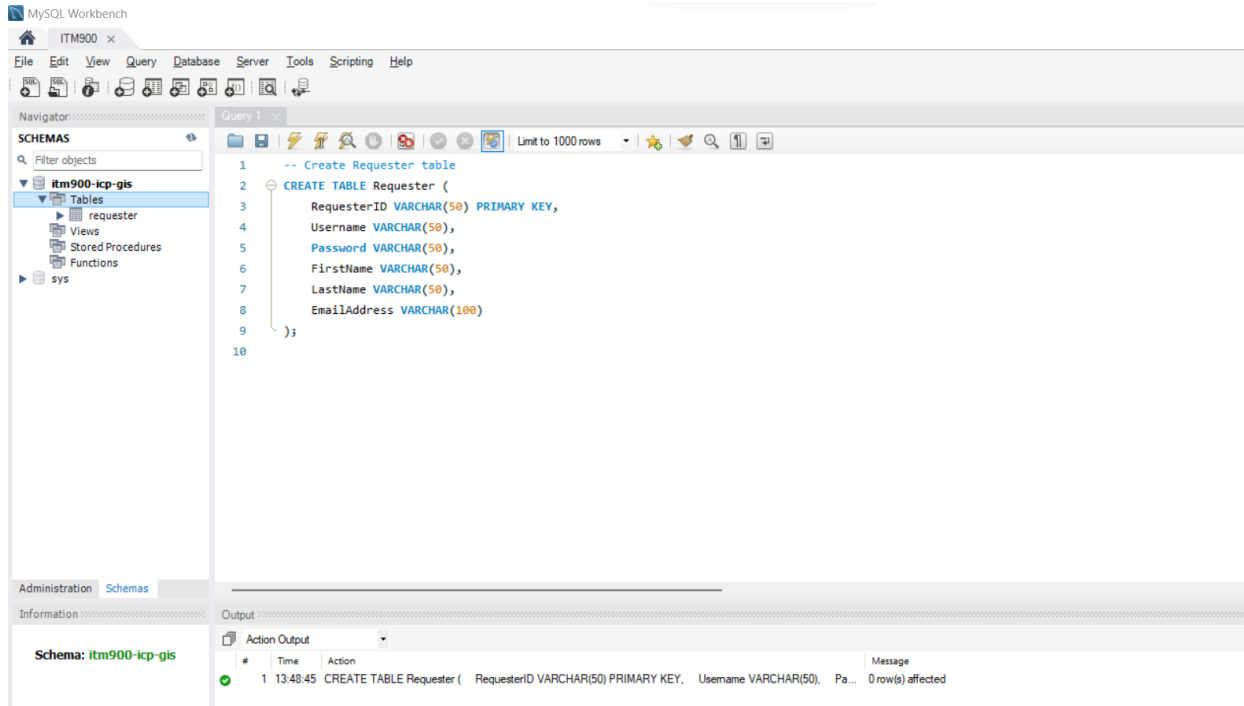
CREATE SCHEMA `itm900-icp-gis` ;



-- Create Requester table

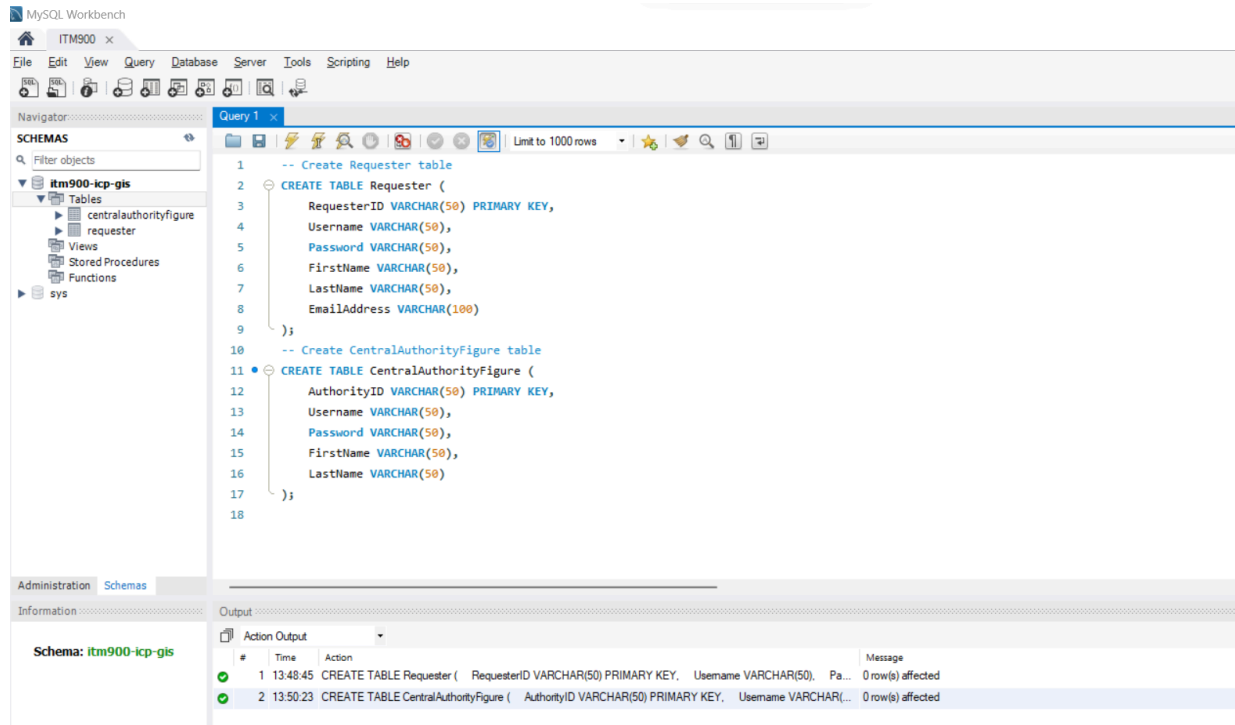
```
CREATE TABLE Requester (
  RequesterID VARCHAR(50) PRIMARY KEY,
  Username VARCHAR(50),
  Password VARCHAR(50),
  FirstName VARCHAR(50),
  LastName VARCHAR(50),
  EmailAddress VARCHAR(100)
);
```

(OpenAI, 2024)

**-- Create CentralAuthorityFigure table**

```
CREATE TABLE CentralAuthorityFigure (
  AuthorityID VARCHAR(50) PRIMARY KEY,
  Username VARCHAR(50),
  Password VARCHAR(50),
  FirstName VARCHAR(50),
  LastName VARCHAR(50)
);
```

(OpenAI, 2024)



-- Create DepartmentManager table

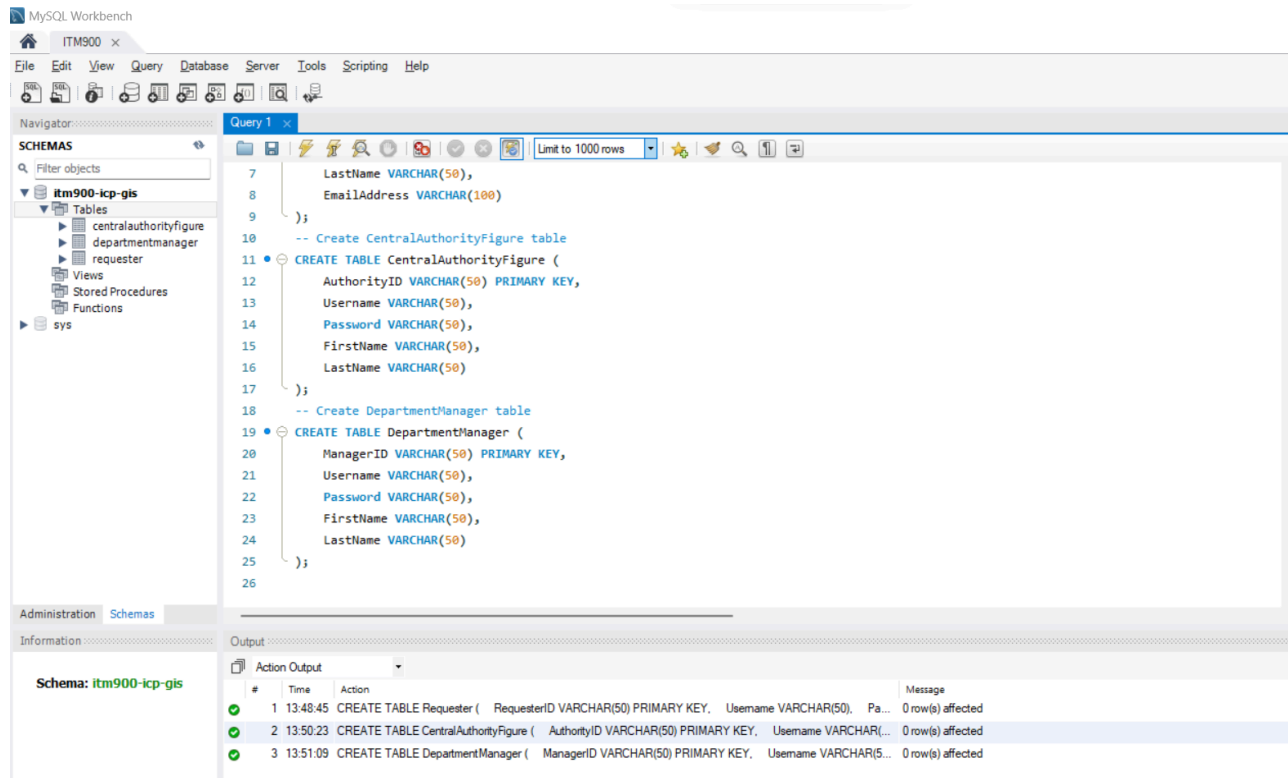
```

CREATE TABLE DepartmentManager (
    ManagerID VARCHAR(50) PRIMARY KEY,
    Username VARCHAR(50),
    Password VARCHAR(50),
    FirstName VARCHAR(50),
    LastName VARCHAR(50)

```

```
);
```

(OpenAI, 2024)



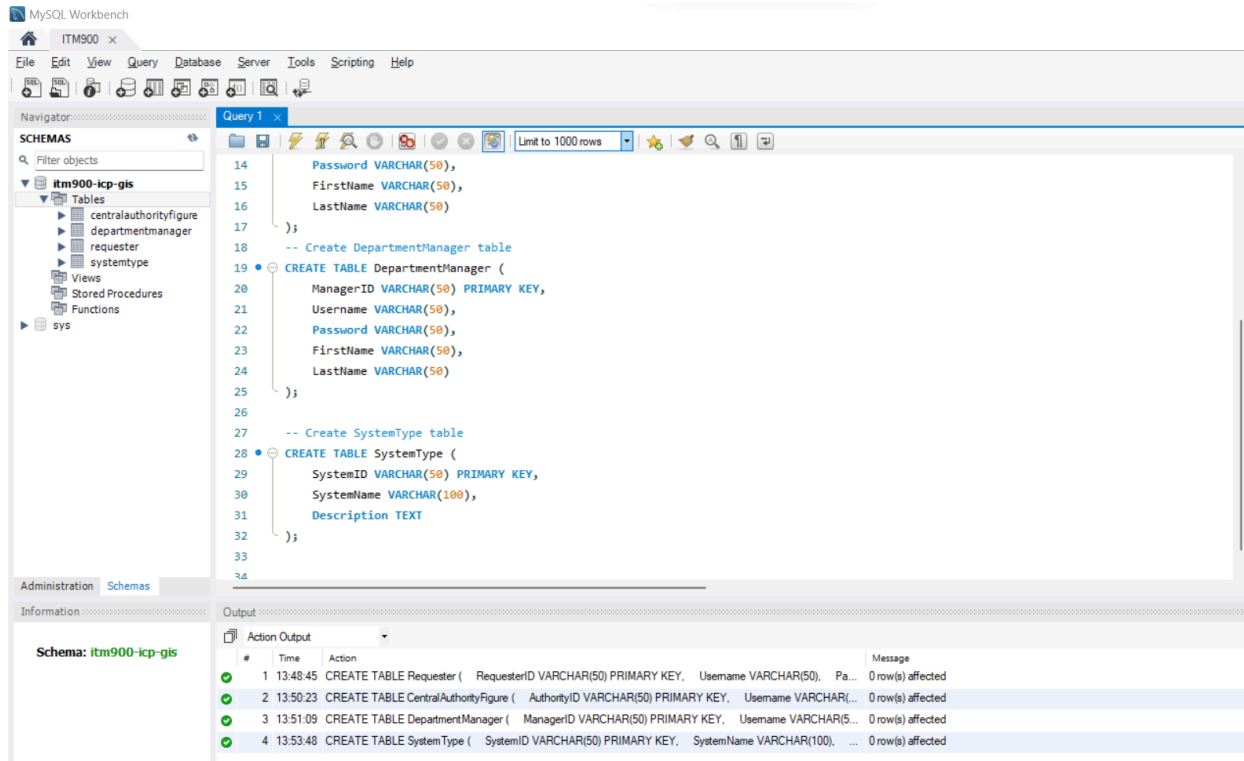
-- Create SystemType table

```

CREATE TABLE SystemType (
    SystemID VARCHAR(50) PRIMARY KEY,
    SystemName VARCHAR(100),
    Description TEXT
);

```

(OpenAI, 2024)



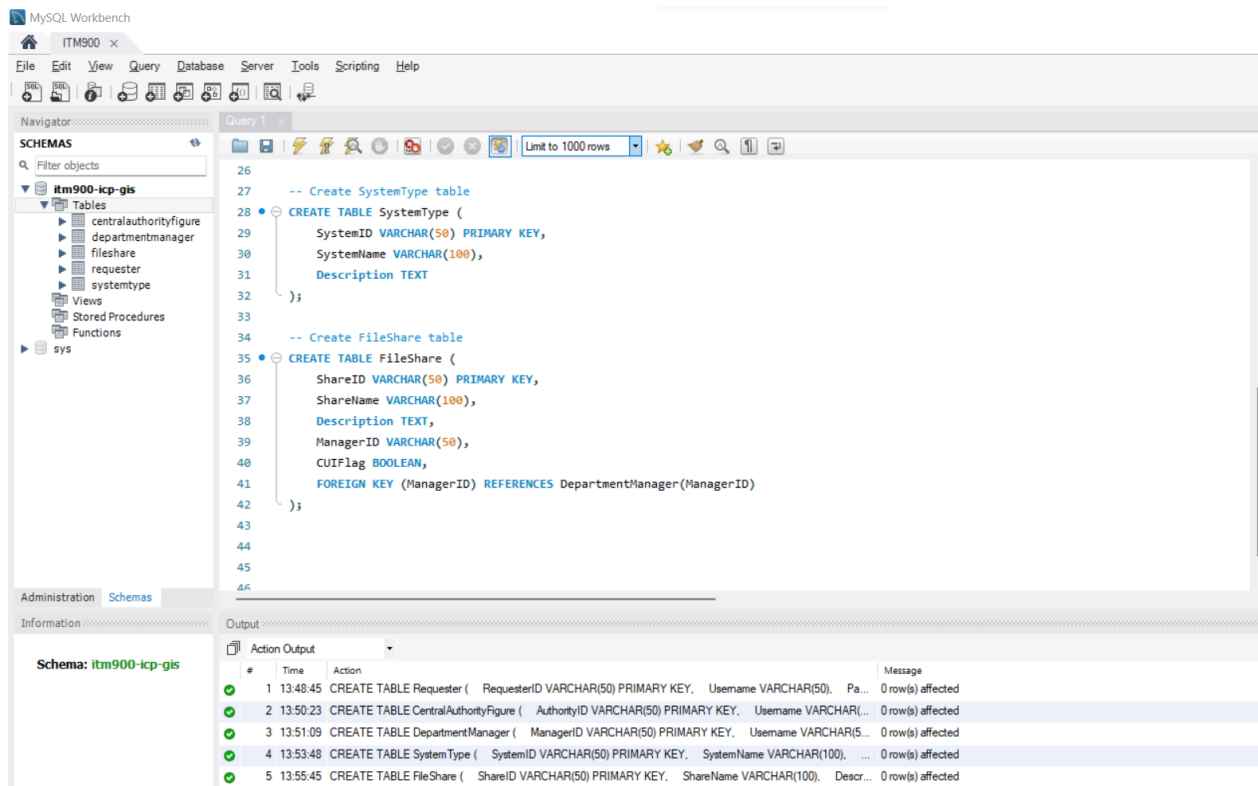
-- Create FileShare table

```

CREATE TABLE FileShare (
    ShareID VARCHAR(50) PRIMARY KEY,
    ShareName VARCHAR(100),
    Description TEXT,
    ManagerID VARCHAR(50),
    CUIFlag BOOLEAN,
    FOREIGN KEY (ManagerID) REFERENCES DepartmentManager(ManagerID)
);

```

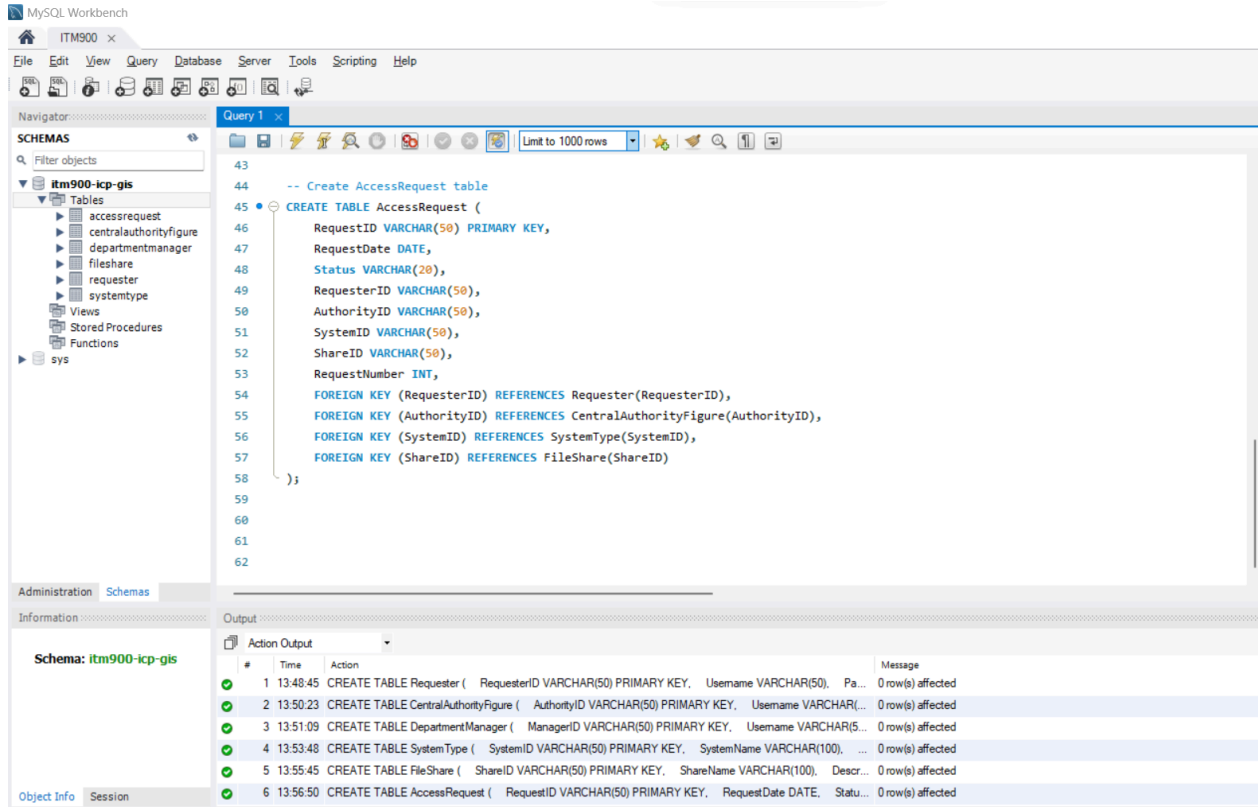
(OpenAI, 2024)



-- Create AccessRequest table

```
CREATE TABLE AccessRequest (
    RequestID VARCHAR(50) PRIMARY KEY,
    RequestDate DATE,
    Status VARCHAR(20),
    RequesterID VARCHAR(50),
    AuthorityID VARCHAR(50),
    SystemID VARCHAR(50),
    ShareID VARCHAR(50),
    RequestNumber INT,
    FOREIGN KEY (RequesterID) REFERENCES Requester(RequesterID),
    FOREIGN KEY (AuthorityID) REFERENCES CentralAuthorityFigure(AuthorityID),
    FOREIGN KEY (SystemID) REFERENCES SystemType(SystemID),
    FOREIGN KEY (ShareID) REFERENCES FileShare(ShareID)
);
```

(OpenAI, 2024)



CRUD Commands

Requester Data Ingestion

RequesterID	Username	Password	FirstName	LastName	EmailAddress
REQR1	j_stamos	jstamos123	John	Stamos	jstamos@icpinc.com
REQR2	m_wang	mwang123	Melissa	Wang	melissa.wang@icpinc.com
REQR3	s_mahinder	smahinder123	Shahiv	Mahinder	smahinder@icpinc.com
REQR4	m_bezos	mbezos123	Michael	Bezos	mbezos@icpinc.com
REQR5	a_lestanza	alestanza123	Aria	Lestanza	alestanza@icpinc.com
REQR6	b_lam	blam123	Benedict	Lam	blam@icpinc.com
REQR7	d_karpinski	dkarpinski123	Daniel	Karpinski	dkarpinski@icpin.com
REQR8	a_joico	ajoico123	Angelina	Joico	ajoico@icpinc.com
REQR9	e_hick	ehick123	Esther	Hick	ehicks@icpinc.com
REQR10	x_zheng	xzheng123	Xi	Zheng	xzheng@icpinc.com

Create:**-- Insert all requesters**

```

INSERT INTO Requester (RequesterID, Username, Password, FirstName, LastName,
EmailAddress)
VALUES
('REQR1', 'j_stamos', 'jstamos123', 'John', 'Stamos', 'jstamos@icpinc.com'),
('REQR2', 'm_wang', 'mwang123', 'Melissa', 'Wang', 'melissa.wang@icpinc.com'),
('REQR3', 's_mahinder', 'smahinder123', 'Shahiv', 'Mahinder', 'smahinder@icpinc.com'),
('REQR4', 'm_bezos', 'mbezos123', 'Michael', 'Bezos', 'mbezos@icpinc.com'),
('REQR5', 'a_lestanza', 'alestanza123', 'Aria', 'Lestanza', 'alestanza@icpinc.com'),
('REQR6', 'b_lam', 'blam123', 'Benedict', 'Lam', 'blam@icpinc.com'),
('REQR7', 'd_karpinski', 'dkarpinski123', 'Daniel', 'Karpinski', 'dkarpinski@icpin.com'),
('REQR8', 'a_joico', 'ajoico123', 'Angelina', 'Joico', 'ajoico@icpinc.com'),
('REQR9', 'e_hick', 'ehick123', 'Esther', 'Hick', 'ehicks@icpinc.com'),
('REQR10', 'x_zheng', 'xzheng123', 'Xi', 'Zheng', 'xzheng@icpinc.com');

```

-- View Requester Table

```
SELECT * FROM Requester;
```

The screenshot shows the MySQL Workbench interface. The left sidebar displays the 'SCHEMAS' tree with 'itm900-icp-gis' selected. The main editor shows the SQL query: `SELECT * FROM Requester;`. The 'Result Grid' at the bottom displays the following data:

RequesterID	Username	Password	FirstName	LastName	EmailAddress
REQR1	j_stamos	jstamos123	John	Stamos	jstamos@icpinc.com
REQR10	x_zheng	xzheng123	Xi	Zheng	xzheng@icpinc.com
REQR2	m_wang	mwang123	Melissa	Wang	melissa.wang@icpinc.com
REQR3	s_mahinder	smahinder123	Shahiv	Mahinder	smahinder@icpinc.com
REQR4	m_bezos	mbezos123	Michael	Bezos	mbezos@icpinc.com
REQR5	a_lestanza	alestanza123	Aria	Lestanza	alestanza@icpinc.com
REQR6	b_lam	blam123	Benedict	Lam	blam@icpinc.com
REQR7	d_karpinski	dkarpinski123	Daniel	Karpinski	dkarpinski@icpin.com
REQR8	a_joico	ajoico123	Angelina	Joico	ajoico@icpinc.com
REQR9	e_hick	ehick123	Esther	Hick	ehicks@icpinc.com

The 'Output' pane at the bottom shows the message: '10 row(s) returned'.

Central Authority Data Ingestion

AuthorityID	Username	Password	FirstName	LastName
CAUTH1	r_lozada	rlozada123	Rodin	Lozada
CAUTH2	m_langlois	mlanglois123	Marc	Langlois

Create:*-- Insert all central authority figures*

```
INSERT INTO CentralAuthorityFigure (AuthorityID, Username, Password, FirstName,
LastName)
```

```
VALUES
```

```
('CAUTH1', 'r_lozada', 'rlozada123', 'Rodin', 'Lozada'),
```

```
('CAUTH2', 'm_langlois', 'mlanglois123', 'Marc', 'Langlois');
```

-- View Central Authority Table

```
SELECT * FROM CentralAuthorityFigure;
```

The screenshot displays the MySQL Workbench interface. On the left, the 'SCHEMAS' pane shows the 'itm900-icp-gis' database with various tables and views. The main editor window contains the following SQL script:

```
-- Insert all central authority figures
INSERT INTO CentralAuthorityFigure (AuthorityID, Username, Password, FirstName, LastName)
VALUES
('CAUTH1', 'r_lozada', 'rlozada123', 'Rodin', 'Lozada'),
('CAUTH2', 'm_langlois', 'mlanglois123', 'Marc', 'Langlois');

-- View Central Authority Table
SELECT * FROM CentralAuthorityFigure;
```

The 'Result Grid' shows the data returned by the SELECT statement:

AuthorityID	Username	Password	FirstName	LastName
CAUTH1	r_lozada	rlozada123	Rodin	Lozada
CAUTH2	m_langlois	mlanglois123	Marc	Langlois

The 'Action Output' pane at the bottom shows the execution results:

#	Time	Action	Message
3	14:25:19	INSERT INTO CentralAuthorityFigure (AuthorityID, Username, Password, FirstName, LastName) VALUES (CA...	2 row(s) affected Records: 2 Duplicates: 0 Warnings: 0
4	14:25:19	SELECT * FROM CentralAuthorityFigure LIMIT 0, 1000	2 row(s) returned

Department Manager Data Ingestion

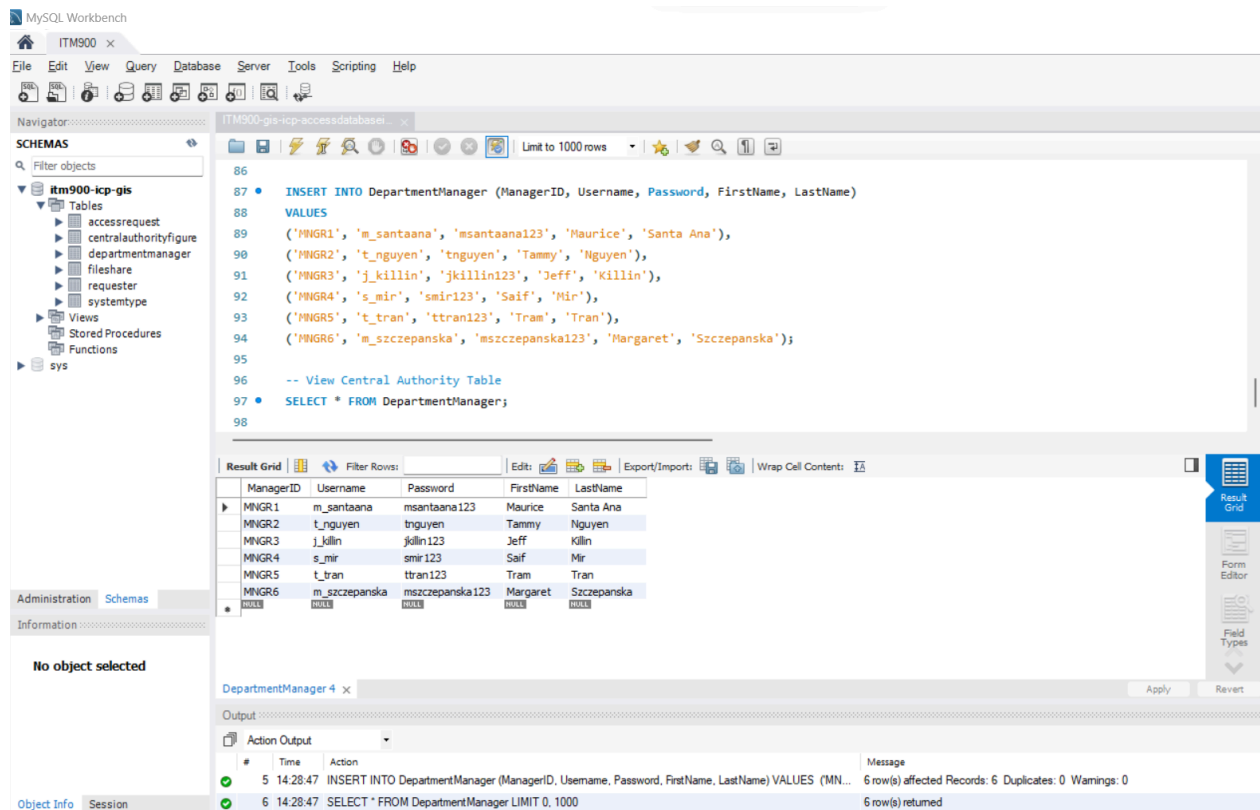
ManagerID	Username	Password	FirstName	LastName
MNGR1	m_santaana	msantaana123	Maurice	Santa Ana
MNGR2	t_nguyen	tnguyen	Tammy	Nguyen
MNGR3	j_killin	jkillin123	Jeff	Killin
MNGR4	s_mir	smir123	Saif	Mir
MNGR5	t_tran	ttran123	Tram	Tran
MNGR6	m_szczepanska	mszczepanska123	Margaret	Szczepanska

-- Insert all department managers

```
INSERT INTO DepartmentManager (ManagerID, Username, Password, FirstName, LastName)
VALUES
('MNGR1', 'm_santaana', 'msantaana123', 'Maurice', 'Santa Ana'),
('MNGR2', 't_nguyen', 'tnguyen', 'Tammy', 'Nguyen'),
('MNGR3', 'j_killin', 'jkillin123', 'Jeff', 'Killin'),
('MNGR4', 's_mir', 'smir123', 'Saif', 'Mir'),
('MNGR5', 't_tran', 'ttran123', 'Tram', 'Tran'),
('MNGR6', 'm_szczepanska', 'mszczepanska123', 'Margaret', 'Szczepanska');
```

-- View Department Manager Table

```
SELECT * FROM DepartmentManager;
```



System Data Ingestion

SystemID	SystemName	Description
SYS1	Common	Common Department
SYS2	Finance	Finance Department
SYS3	SalesMarketing	Sales and Marketing Department
SYS4	Management	Management Department
SYS5	Engineering	Engineering Department
SYS6	Quality	Quality Department

-- Insert all systems

```

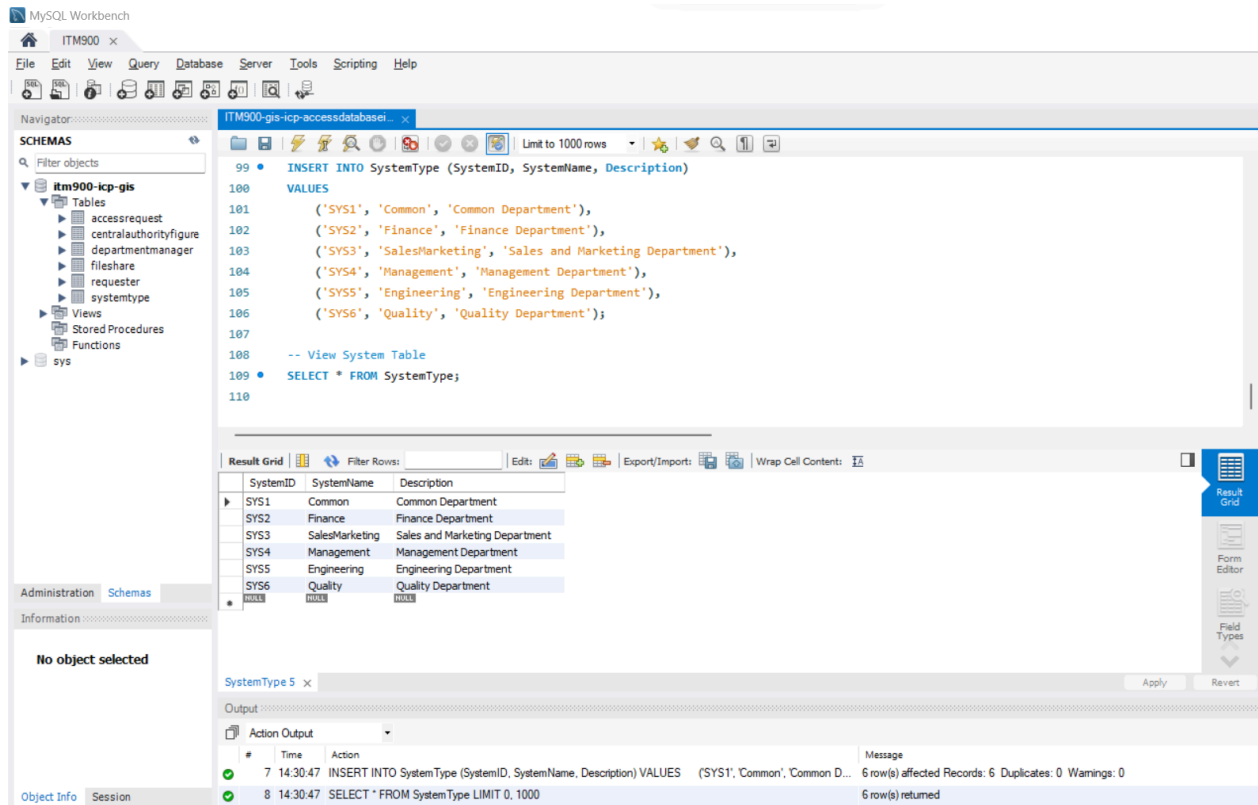
INSERT INTO SystemType (SystemID, SystemName, Description)
VALUES
('SYS1', 'Common', 'Common Department'),
('SYS2', 'Finance', 'Finance Department'),
('SYS3', 'SalesMarketing', 'Sales and Marketing Department'),
('SYS4', 'Management', 'Management Department'),

```

```
('SYS5', 'Engineering', 'Engineering Department'),
('SYS6', 'Quality', 'Quality Department');
```

```
-- View System Table
```

```
SELECT * FROM SystemType;
```



Fileshare Data Ingestion

ShareID	ShareName	Description	ManagerID	CUIFlag
SHR1	CorporatePolicies	Common	MNGR1	False
SHR2	FinancialReports	Finance	MNGR2	True
SHR3	SalesPipeline	SalesMarketing	MNGR3	False
SHR4	LeadershipResources	Management	MNGR4	False
SHR5	EngineeringProjects	Engineering	MNGR5	True
SHR6	QualityControlDocs	Quality	MNGR6	True

```
-- Insert all file shares
```

```
INSERT INTO FileShare (ShareID, ShareName, Description, ManagerID, CUIFlag)
```

VALUES

```
( 'SHR1', 'CorporatePolicies', 'Common', 'MNGR1', FALSE),
( 'SHR2', 'FinancialReports', 'Finance', 'MNGR2', TRUE),
( 'SHR3', 'SalesPipeline', 'SalesMarketing', 'MNGR3', FALSE),
( 'SHR4', 'LeadershipResources', 'Management', 'MNGR4', FALSE),
( 'SHR5', 'EngineeringProjects', 'Engineering', 'MNGR5', TRUE),
( 'SHR6', 'QualityControlDocs', 'Quality', 'MNGR6', TRUE);
```

-- View File Share Table

```
SELECT * FROM FileShare;
```

The screenshot shows the MySQL Workbench interface. The SQL editor contains the following script:

```
112 INSERT INTO FileShare (ShareID, ShareName, Description, ManagerID, CUIFlag)
113 VALUES
114 ('SHR1', 'CorporatePolicies', 'Common', 'MNGR1', FALSE),
115 ('SHR2', 'FinancialReports', 'Finance', 'MNGR2', TRUE),
116 ('SHR3', 'SalesPipeline', 'SalesMarketing', 'MNGR3', FALSE),
117 ('SHR4', 'LeadershipResources', 'Management', 'MNGR4', FALSE),
118 ('SHR5', 'EngineeringProjects', 'Engineering', 'MNGR5', TRUE),
119 ('SHR6', 'QualityControlDocs', 'Quality', 'MNGR6', TRUE);
120
121 -- View File Share Table
122 SELECT * FROM FileShare;
123
```

The **Result Grid** displays the following data:

ShareID	ShareName	Description	ManagerID	CUIFlag
SHR1	CorporatePolicies	Common	MNGR1	0
SHR2	FinancialReports	Finance	MNGR2	1
SHR3	SalesPipeline	SalesMarketing	MNGR3	0
SHR4	LeadershipResources	Management	MNGR4	0
SHR5	EngineeringProjects	Engineering	MNGR5	1
SHR6	QualityControlDocs	Quality	MNGR6	1

The **Table: fileshare** structure is shown in the left pane:

```
Columns:
  ShareID    varchar(50) PK
  ShareName  varchar(100)
  Description text
  ManagerID  varchar(50)
  CUIFlag    tinyint(1)
```

The **Output** pane shows the execution results:

```
1 14:34:45 INSERT INTO FileShare (ShareID, ShareName, Description, ManagerID, CUIFlag) VALUES ('SHR1', 'Corporate... 6 row(s) affected Records: 6 Duplicates: 0 Warnings: 0
2 14:34:45 SELECT * FROM FileShare LIMIT 0, 1000 6 row(s) returned
```

Access Request Data Ingestion

RequestID	RequestDate	Status	RequesterID	AuthorityID	SystemID	ShareID	RequestNumber
REQ1	2024-01-01	Approved	REQR1	CAUTH1	SYS1	SHR1	1
REQ2	2024-01-11	Pending	REQR2	CAUTH2	SYS3	SHR3	2
REQ3	2024-01-22	Pending	REQR3	CAUTH1	SYS6	SHR6	3
REQ4	2024-01-31	Approved	REQR4	CAUTH2	SYS3	SHR3	4
REQ5	2024-01-31	Approved	REQR4	CAUTH1	SYS3	SHR3	5
REQ6	2024-02-02	Approved	REQR5	CAUTH1	SYS5	SHR5	6
REQ7	2024-02-22	Approved	REQR6	CAUTH2	SYS5	SHR5	7
REQ8	2024-03-03	Pending	REQR7	CAUTH1	SYS4	SHR4	8
REQ9	2024-03-07	Approved	REQR8	CAUTH2	SYS3	SHR3	9
REQ10	2024-03-22	Approved	REQR10	CAUTH1	SYS6	SHR6	10

-- Insert all access requests

INSERT INTO AccessRequest (RequestID, RequestDate, Status, RequesterID, AuthorityID, SystemID, ShareID, RequestNumber)

VALUES

('REQ1', '2024-01-01', 'Approved', 'REQR1', 'CAUTH1', 'SYS1', 'SHR1', 1),
 ('REQ2', '2024-01-11', 'Pending', 'REQR2', 'CAUTH2', 'SYS3', 'SHR3', 2),
 ('REQ3', '2024-01-22', 'Pending', 'REQR3', 'CAUTH1', 'SYS6', 'SHR6', 3),
 ('REQ4', '2024-01-31', 'Approved', 'REQR4', 'CAUTH2', 'SYS3', 'SHR3', 4),
 ('REQ5', '2024-01-31', 'Approved', 'REQR4', 'CAUTH1', 'SYS3', 'SHR3', 5),
 ('REQ6', '2024-02-02', 'Approved', 'REQR5', 'CAUTH1', 'SYS5', 'SHR5', 6),
 ('REQ7', '2024-02-22', 'Approved', 'REQR6', 'CAUTH2', 'SYS5', 'SHR5', 7),
 ('REQ8', '2024-03-03', 'Pending', 'REQR7', 'CAUTH1', 'SYS4', 'SHR4', 8),
 ('REQ9', '2024-03-07', 'Approved', 'REQR8', 'CAUTH2', 'SYS3', 'SHR3', 9),
 ('REQ10', '2024-03-22', 'Approved', 'REQR10', 'CAUTH1', 'SYS6', 'SHR6', 10);

-- View Access Requests Table

SELECT * FROM AccessRequest;

The screenshot shows the MySQL Workbench interface. The top toolbar includes icons for File, Edit, View, Query, Database, Server, Tools, Scripting, and Help. The left sidebar shows the 'SCHEMAS' tab with a tree view of the database structure, including tables like 'accessrequest', 'centralauthorityfigure', 'departmentmanager', 'fileshare', 'requester', and 'systemtype'. The main window displays an SQL query in the 'Query' tab:

```

126 • INSERT INTO AccessRequest (RequestID, RequestDate, Status, RequesterID, AuthorityID, SystemID, ShareID, RequestNumber)
127 VALUES
128 ('REQ1', '2024-01-01', 'Approved', 'REQR1', 'CAUTH1', 'SYS1', 'SHR1', 1),
129 ('REQ2', '2024-01-11', 'Pending', 'REQR2', 'CAUTH2', 'SYS3', 'SHR3', 2),
130 ('REQ3', '2024-01-22', 'Pending', 'REQR3', 'CAUTH1', 'SYS6', 'SHR6', 3),
131 ('REQ4', '2024-01-31', 'Approved', 'REQR4', 'CAUTH2', 'SYS3', 'SHR3', 4),
132 ('REQ5', '2024-01-31', 'Approved', 'REQR4', 'CAUTH1', 'SYS3', 'SHR3', 5),
133 ('REQ6', '2024-02-02', 'Approved', 'REQR5', 'CAUTH1', 'SYS5', 'SHR5', 6),
134 ('REQ7', '2024-02-22', 'Approved', 'REQR6', 'CAUTH2', 'SYS5', 'SHR5', 7),
135 ('REQ8', '2024-03-03', 'Pending', 'REQR7', 'CAUTH1', 'SYS4', 'SHR4', 8),
136 ('REQ9', '2024-03-07', 'Approved', 'REQR8', 'CAUTH2', 'SYS3', 'SHR3', 9),
137 ('REQ10', '2024-03-22', 'Approved', 'REQR10', 'CAUTH1', 'SYS6', 'SHR6', 10);
138

```

Below the query, the 'Result Grid' shows the data returned by the query. The table has columns: RequestID, RequestDate, Status, RequesterID, AuthorityID, SystemID, ShareID, and RequestNumber. The data is as follows:

RequestID	RequestDate	Status	RequesterID	AuthorityID	SystemID	ShareID	RequestNumber
REQ1	2024-01-01	Approved	REQR1	CAUTH1	SYS1	SHR1	1
REQ2	2024-01-11	Pending	REQR2	CAUTH2	SYS3	SHR3	2
REQ3	2024-01-22	Pending	REQR3	CAUTH1	SYS6	SHR6	3
REQ4	2024-01-31	Approved	REQR4	CAUTH2	SYS3	SHR3	4
REQ5	2024-01-31	Approved	REQR4	CAUTH1	SYS3	SHR3	5
REQ6	2024-02-02	Approved	REQR5	CAUTH1	SYS5	SHR5	6
REQ7	2024-02-22	Approved	REQR6	CAUTH2	SYS5	SHR5	7
REQ8	2024-03-03	Pending	REQR7	CAUTH1	SYS4	SHR4	8
REQ9	2024-03-07	Approved	REQR8	CAUTH2	SYS3	SHR3	9
REQ10	2024-03-22	Approved	REQR10	CAUTH1	SYS6	SHR6	10

The bottom of the interface shows the 'Output' tab with a message: '10 row(s) affected Records: 10 Duplicates: 0 Warnings: 0'.

SQL Database Prototype

Use Case 1: Create

- The code successfully inserts a new requester, Matthew Drumonde, into the Requester table.
- It also inserts a new access request for Matthew Drumonde into the AccessRequests table.

-- Create new requester Matthew Drumonde - REQR11

```

INSERT INTO Requester (RequesterID, Username, Password, FirstName, LastName,
EmailAddress)
VALUES
('REQR11', 'm_drumonde', 'mdrumonde123', 'Matthew', 'Drumonde', 'mdrumonde@icpinc.com');

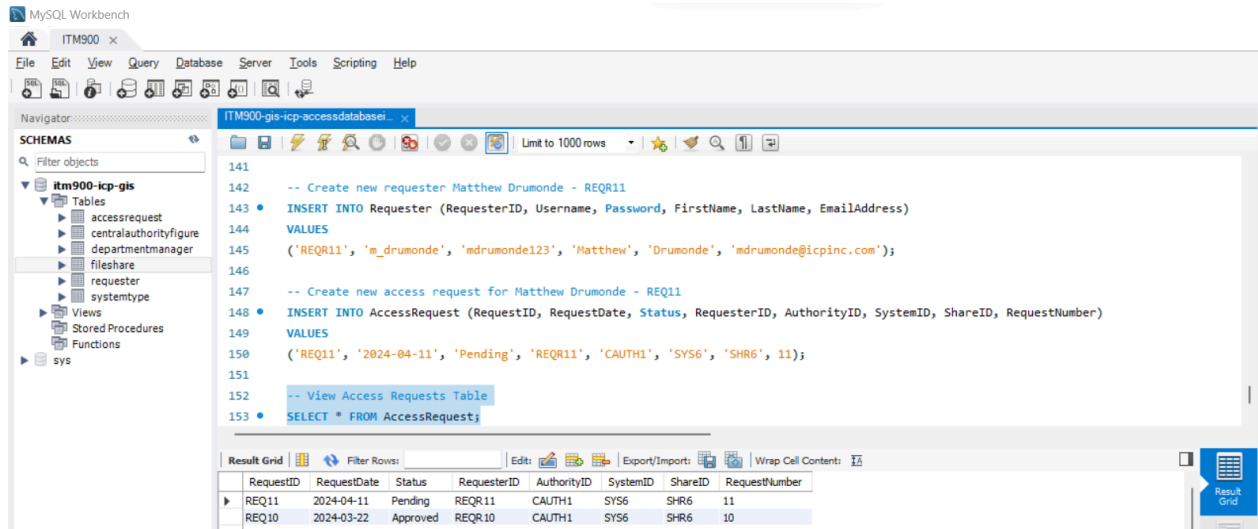
```

-- Create new access request for Matthew Drumonde - REQ11

```

INSERT INTO AccessRequest (RequestID, RequestDate, Status, RequesterID, AuthorityID,
SystemID, ShareID, RequestNumber)
VALUES
('REQ11', '2024-04-11', 'Pending', 'REQR11', 'CAUTH1', 'SYS6', 'SHR6', 11);

```

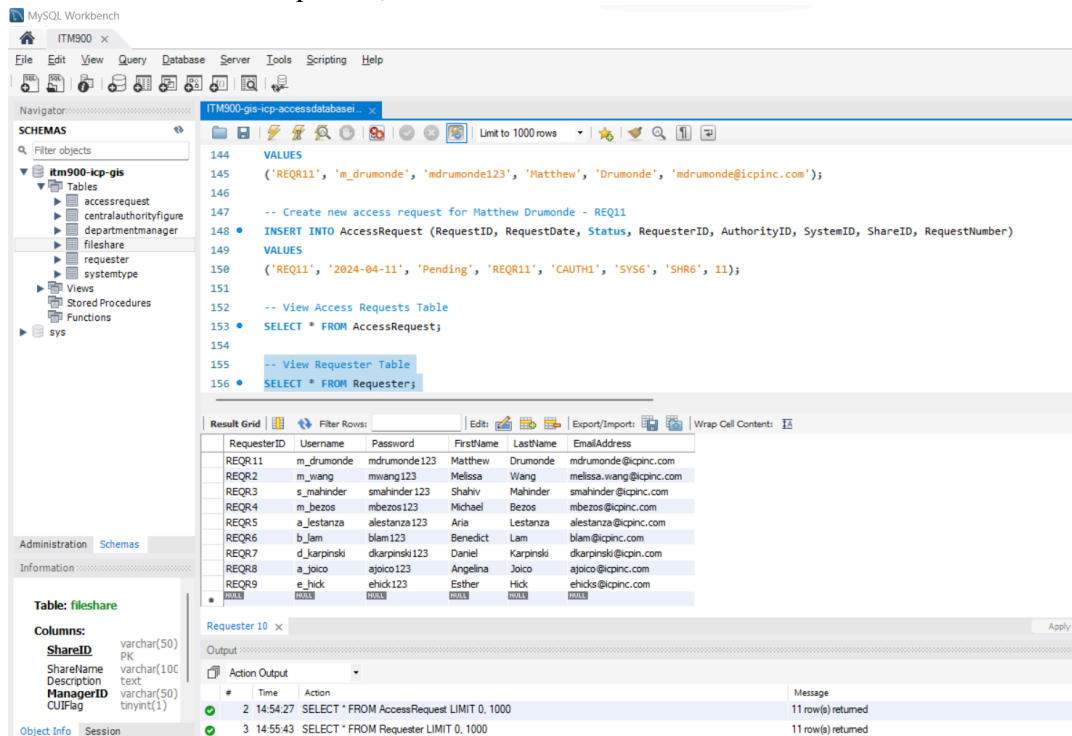


Use Case 2: Read

- The SELECT statements correctly retrieve data from the Requester and AccessRequests tables.
- The JOIN query combines data from both tables to show access requests along with associated requester information.

-- Select all requesters

SELECT * FROM Requester;



-- Select all access requests

```
SELECT * FROM AccessRequest ORDER BY RequestNumber Desc;
```

The screenshot shows the MySQL Workbench interface. The left sidebar displays the 'SCHEMAS' tree with 'itm900-icp-gis' selected. The main editor window contains a SQL script with several queries. The 'Result Grid' at the bottom shows the results of the query 'SELECT * FROM AccessRequest ORDER BY RequestNumber Desc;'. The results are displayed in a table with columns: RequestID, RequestDate, Status, RequesterID, AuthorityID, SystemID, ShareID, and RequestNumber. The table contains 11 rows of data. The 'Output' pane at the bottom shows the execution of the query, indicating that 11 rows were returned.

RequestID	RequestDate	Status	RequesterID	AuthorityID	SystemID	ShareID	RequestNumber
REQ11	2024-04-11	Pending	REQR11	CAUTH1	SYS6	SHR6	11
REQ10	2024-03-22	Approved	REQR10	CAUTH1	SYS6	SHR6	10
REQ9	2024-03-07	Approved	REQR8	CAUTH2	SYS3	SHR3	9
REQ8	2024-03-03	Pending	REQR7	CAUTH1	SYS4	SHR4	8
REQ7	2024-02-22	Approved	REQR6	CAUTH2	SYS5	SHR5	7
REQ6	2024-02-02	Approved	REQR5	CAUTH1	SYS5	SHR5	6
REQ5	2024-01-31	Approved	REQR4	CAUTH1	SYS3	SHR3	5
REQ4	2024-01-31	Approved	REQR4	CAUTH2	SYS3	SHR3	4

-- Select access requests along with associated requester information

```
SELECT AccessRequest.*, Requester.FirstName, Requester.LastName
```

```
FROM AccessRequest
```

```
JOIN Requester ON AccessRequest.RequesterID = Requester.RequesterID ORDER BY RequestNumber Desc;
```

MySQL Workbench interface showing a SQL query and its results.

Query:

```
-- View Requester Table
159 • SELECT * FROM Requester;
160
161 -- Select all requesters
162 • SELECT * FROM Requester;
163
164 -- Select all access requests
165 • SELECT * FROM AccessRequest ORDER BY RequestNumber Desc;
166
167 -- Select access requests along with associated requester information
168 • SELECT AccessRequest.*, Requester.FirstName, Requester.LastName
169 FROM AccessRequest
170 JOIN Requester ON AccessRequest.RequesterID = Requester.RequesterID ORDER BY RequestNumber Desc;
171
172
```

Result Grid:

RequestID	RequestDate	Status	RequesterID	AuthorityID	SystemID	ShareID	RequestNumber	FirstName	LastName
REQ11	2024-04-11	Pending	REQ11	CAUTH1	SYS6	SHR6	11	Matthew	Drumonde
REQ10	2024-03-22	Approved	REQ10	CAUTH1	SYS6	SHR6	10	Xi	Zheng
REQ9	2024-03-07	Approved	REQ8	CAUTH2	SYS3	SHR3	9	Angela	Jolco
REQ8	2024-03-03	Pending	REQ7	CAUTH1	SYS4	SHR4	8	Daniel	Karpinski
REQ7	2024-02-22	Approved	REQ6	CAUTH2	SYS5	SHR5	7	Benedict	Lam
REQ6	2024-02-02	Approved	REQ5	CAUTH1	SYS5	SHR5	6	Aria	Lestanza
REQ5	2024-01-31	Approved	REQ4	CAUTH1	SYS3	SHR3	5	Michael	Bezos
REQ4	2024-01-31	Approved	REQ4	CAUTH2	SYS3	SHR3	4	Michael	Bezos

Action Output:

#	Time	Action	Message
38	15:11:44	SELECT * FROM AccessRequest ORDER BY RequestNumber Desc LIMIT 0, 1000	11 row(s) returned
39	15:12:39	SELECT AccessRequest.*, Requester.FirstName, Requester.LastName FROM AccessRequest JOIN Requester ON AccessRequest.RequesterID = Requester.RequesterID ORDER BY RequestNumber Desc	11 row(s) returned

Use Case 3: Update

- The UPDATE statements correctly modify data in the Requester and AccessRequests tables.
- One updates a requester's password, and the other updates the status of an access request.

-- Update a requester's password

UPDATE Requester

SET Password = 'mdrumonde321'

WHERE RequesterID = 'REQ11';

-- Update the status of an access request

UPDATE AccessRequest

SET Status = 'Approved'

WHERE RequestID = 'REQ11';

-- View passwords (not recommended for production use - proper security measures need to be in place to protect them.)

SELECT R.Password, R.FirstName, R.LastName, A.Status, A.RequesterID, A.RequestID

FROM Requester R

JOIN AccessRequest A ON R.RequesterID = A.RequesterID;

MySQL Workbench interface showing a query editor and a result grid.

Query Editor:

```

168
169 -- Update a requester's password
170 • UPDATE Requester
171   SET Password = 'mdrumonde321'
172   WHERE RequesterID = 'REQR11';
173
174 -- Update the status of an access request
175 • UPDATE AccessRequest
176   SET Status = 'Approved'
177   WHERE RequestID = 'REQ11';
178
179 -- View passwords (not recommended for production use - proper security measures need to be in place to protect them.)
180 • SELECT R.Password, R.FirstName, R.LastName, A.Status, A.RequesterID, A.RequestID
181   FROM Requester R
182  JOIN AccessRequest A ON R.RequesterID = A.RequesterID;

```

Result Grid:

Password	FirstName	LastName	Status	RequesterID	RequestID
jstamos123	John	Stamos	Approved	REQR1	REQ1
xzheng123	Xi	Zheng	Approved	REQR10	REQ10
mdrumonde321	Matthew	Drumonde	Approved	REQR11	REQ11
mwang123	Melissa	Wang	Pending	REQR2	REQ2
smahinder123	Shahiv	Mahinder	Pending	REQR3	REQ3
mbezoz123	Michael	Bezos	Approved	REQR4	REQ4
mbezoz123	Michael	Bezos	Approved	REQR4	REQ5
alestanza123	Ania	Lestanza	Approved	REQR5	REQ6

Table: fileshare

Columns:

- ShareID: varchar(50) PK
- ShareName: varchar(100)
- Description: text
- ManagerID: varchar(50)
- CUIFlag: tinyint(1)

Action Output:

#	Time	Action	Message
7	15:13:09	SELECT R.Password, R.FirstName, R.LastName, A.Status, A.RequesterID FROM Requester R JOIN AccessR...	11 row(s) returned
8	15:13:55	SELECT R.Password, R.FirstName, R.LastName, A.Status, A.RequesterID, A.RequestID FROM Requester R ...	11 row(s) returned

Use Case 4: Delete

- The DELETE statements correctly remove data from the AccessRequests and Requester tables.

-- Delete an access request

```
DELETE FROM AccessRequest
WHERE RequestID = 'REQ11';
```

-- Delete a requester

```
DELETE FROM Requester
WHERE RequesterID = 'REQR11';
```

-- View access request table with first name, last name, request ID, requester ID, and status

```
SELECT R.FirstName, R.LastName, AR.RequestID, AR.RequesterID, AR.Status
FROM Requester R
JOIN AccessRequest AR ON R.RequesterID = AR.RequesterID;
```

The screenshot displays the MySQL Workbench interface. The left sidebar shows the 'SCHEMAS' tree with 'itm900-icp-gis' expanded, listing tables like 'accessrequest', 'centralauthorityfigure', 'departmentmanager', 'fileshare', 'requester', and 'systemtype'. The main editor shows a SQL script with the following queries:

```
185
186 -- Delete an access request
187 • DELETE FROM AccessRequest
188   WHERE RequestID = 'REQ11';
189
190 -- Delete a requester
191 • DELETE FROM Requester
192   WHERE RequesterID = 'REQR11';
193
194 -- View access request table with first name, last name, request ID, requester ID, and status
195
196 • SELECT R.FirstName, R.LastName, AR.RequestID, AR.RequesterID, AR.Status
197   FROM Requester R
198  JOIN AccessRequest AR ON R.RequesterID = AR.RequesterID;
199
```

The 'Result Grid' shows the output of the last query, displaying 10 rows of data:

FirstName	LastName	RequestID	RequesterID	Status
John	Stamos	REQ1	REQR1	Approved
Xi	Zheng	REQ10	REQR10	Approved
Melissa	Wang	REQ2	REQR2	Pending
Shahiv	Mahinder	REQ3	REQR3	Pending
Michael	Bezos	REQ4	REQR4	Approved
Michael	Bezos	REQ5	REQR4	Approved
Aria	Lestanza	REQ6	REQR5	Approved
Benedict	Lam	REQ7	REQR6	Approved

The 'Table: fileshare' information panel on the left lists columns: ShareID (varchar(50), PK), ShareName (varchar(100)), Description (text), ManagerID (varchar(50)), and CUIFlag (tinyint(1)). The 'Output' panel at the bottom shows the execution log:

#	Time	Action	Message
3	15:19:26	DELETE FROM Requester WHERE RequesterID = 'REQR11'	1 row(s) affected
4	15:19:33	SELECT R.FirstName, R.LastName, AR.RequestID, AR.RequesterID, AR.Status FROM Requester R JOIN Ac...	10 row(s) returned

Client Wireframes Microsoft Power Apps User Interface Provided by Client (UI)

Use Case 1: Requester onboarding

Requester Onboarding Form

Access Request Form

First Name: Last Name: Email:

Authorization:

Hardware

System Type: Mobile Phone: ☐ Off

Software

M365 Subscription Type: Install OpenVPN: ☒ On Install MS Office: ☒ On

Additional Software:

Shares Required

Common Share: ☒ On Finance Share: ☐ Off Sales & Marketing Share: ☒ On

Use Case 2: Access to Specific Systems

System Access Microsoft PowerApps Interface

Power Apps | SystemAccess

System Access

Date	First Name	Last Name	Email	Common	Finance	Sales & Marketing	Management	Engineering	Quality	
03-13-24	John	Stamos	jstamos@icpinc.com	☒	☒	☒	☒	☒	☒	>
03-14-24	Melissa	Wang	melissa.wang@icpinc.com	☒		☒		☒		>
03-14-24	Shahiv	Mahinder	smahinder@icpinc.com						☒	>
03-14-24	Michael	Bezos	mbezos	☒		☒				>
03-14-24	Aria	Lestanza	alestanza@icpinc.com	☒	☒		☒			>
03-14-24	Benedict	Lam	blam@icpinc.com	☒				☒	☒	>
03-14-24	Daniel	Karpinski	dkarpinski@icpinc.com	☒		☒	☒	☒		>
03-14-24	Angelina	Joico	ajico@icpinc.com	☒			☒			>
03-14-24	Esther	Hick	ehicks@icpinc.com	☒		☒				>
03-14-24	Xi	Zheng	xzheng@icpinc.com	☒	☒		☒		☒	>

Requests Currently Open: 10 Requests Awaiting Authorization: 3 of 10

8. Implementation and deployment & risk management plan for the new IS solution



**Access Controls Management System
Business Projects-IT-Enabled
Deployment and Risk Management Phase**

8.1 Implementation and deployment activities

1. Testing Phase:

To complete this venture, the project will go through a rigorous testing session to determine the functional reliability, dependability, and safety of the system access approval process framework. This entails subjecting all individual components to unit testing to check each one's functionality, module testing to check whether the modules are working together as expected, and user acceptance testing where the system will be put through a trial period to test how it performs against user specifications. All defects and bugs that we find during quality testing will be acted upon so that the system will be bug free and of high standards in quality and reliability.

2. Deployment Phase:

After the tests and system acceptance, the deployment phase follows. Accordingly, a big emphasis is placed on scheduling and management in order to lessen difficulties for ICP's operation. The project team will negotiate interruptions to service while installing and configuring the system into the current production infrastructure so as to make the process of deployment as smooth as possible. Final testing will be done in a live environment to ensure system stability and performance of the system before it is made available to end users.

3. Training and Documentation:

Delivery of the system and all required documents involved, such as the training materials for the end users, administrators, and decision makers will follow. Training seminars will be developed that will acquaint users with the system's capabilities, making sure they are knowledgeable of its peculiarities so they can use it efficiently day by day. Furthermore, user manuals and supplemental materials will be provided to ensure effective implementation, issue fixing, and maintenance of the implemented process, thereby reinforcing the implementation and deployment processes.

4. Rollout and Adoption:

The deployment and adoption phase will be centered around solid communication strategies that will communicate the system's benefits to stakeholders and low risk integration into ICP's operational processes. This will be done by providing clear, precise, and continuous information about the purpose and features of the system, as well as assuming the role of an aid during this period of transition. The feedback will be actively requested from agents, customers, and stakeholders to identify any issue areas or the need for additional training. In this way, the system could be continually improved and refined through on-going optimization.

5. Monitoring and Maintenance:

Last but not least would be the monitoring and maintenance that establish a monitoring mechanism to assess system performance, the number of users, and the security level. Mandatory maintenance procedures called for the implementation of solutions to address any emergent issues and update the system to conform to the standard of security. Periodic assessments will be done to evaluate if the system is meeting organizational goals and to identify areas where improvement can begin. Through continual and forward-looking scrutiny of system problems and

the prompt and intuitive actions taken, ICP is able to guarantee the longevity and sustainability of the newly adapted system.

8.2 Risk assessment and mitigation activities

The project faces several critical risks, including implementation delays, stakeholder resistance, compliance pitfalls, and security vulnerabilities. To mitigate these risks, comprehensive strategies such as continuous progress tracking, stakeholder engagement, compliance reviews, and stringent security measures will be implemented, ensuring successful project execution and regulatory adherence.

1. Implementation Delays:

- **Probability:** Medium
- **Impact:** High
- **Risk Management Plan:**
 - Establish continuous tracking of the project's progress through regular status updates and meetings.
 - Proactively identify potential challenges or unforeseen complications in transitioning to the centralized management platform using Microsoft Power Apps.
 - Consistently allocate necessary resources to address implementation barriers.
 - Develop a contingency plan to mitigate delays, including alternative solutions or additional support from technical experts.
- **Owner/Responsible Party:** TMU Capstone Team and Golden Integrated Solutions (GIS)

2. Stakeholder Resistance:

- **Probability:** High
- **Impact:** Medium
- **Risk Management Plan:**
 - Develop comprehensive stakeholder engagement strategies to address resistance among stakeholders, including companies and administration.
 - Clearly communicate the benefits of the project and how it aligns with the organization's goals.
 - Provide training and support to stakeholders to facilitate their understanding and adoption of new technologies.
 - Address concerns and questions rapidly to alleviate resistance and foster cooperation.
- **Owner/Responsible Party:** TMU Capstone Team and ICP management

3. Compliance Pitfalls:

- **Probability:** Medium
- **Impact:** High
- **Risk Management Plan:**
 - Conduct comprehensive compliance reviews to ensure adherence to NIST 800-171, CUI, and CMMC standards throughout the project lifecycle.

- Implement measures to proactively meet regulatory requirements, including regular audits and risk prevention activities.
- Engage regulatory compliance officers within ICP to provide guidance and support in maintaining compliance.
- Incorporate regulatory compliance considerations into all project phases, from planning to execution.
- **Owner/Responsible Party:** TMU Capstone Team and regulatory compliance officers within ICP
- 4. **Ineffective User Account Management and Security Configurations:**
 - **Probability:** Medium to High
 - **Impact:** High
 - **Risk Management Plan:**
 - Implement stringent procedures for user account management and security configurations, including regular audits and assessments.
 - Adopt a defense-in-depth strategy by employing multiple layers of security controls to mitigate vulnerabilities.
 - Conduct regular security awareness training programs to educate users about best practices and potential risks.
 - Enhance physical security measures to prevent unauthorized access to critical systems and data.
 - **Owner/Responsible Party:** TMU Capstone Team and IT Security Department
- 5. **Lack of Regular Access Reviews:**
 - **Probability:** Medium
 - **Impact:** High
 - **Risk Management Plan:**
 - Implement periodic access reviews to identify and revoke unnecessary access privileges.
 - Develop automated processes for access review to ensure efficiency and accuracy.
 - Enforce strict access control policies to minimize the risk of unauthorized access.
 - Provide training to personnel responsible for access reviews to enhance their effectiveness.
 - **Owner/Responsible Party:** TMU Capstone Team and IT Security Department

By diligently executing these risk management plans, the project can effectively identify, mitigate, and minimize potential risks, ensuring the successful implementation of the centralized access management platform and adherence to compliance standards.

9. Client Organization Feedback



Access Controls Management System
Business Projects-IT-Enabled
Client Feedback

ITM Capstone Project Community Partnership***Partner Organization*****Name:** ICP**Address:** 49 Howden Road, Scarborough, ON, Canada M1R 3C7**Website:** icpinc.com

Overall Organization's Mission: *Since 1985, International Custom Products Inc (ICP) has been a market leader in the engineering and manufacture of custom-designed, mechanically stitched textile-based solutions.*

Primary Organization Contact**Full Name:** Rodin Lozada**Job Title:** VP Finance**Email:** rlozada@icpinc.com**Work Phone Number:** 416 285 4311**Mobile Phone Number:** 416 285 4311***Project:***

1. **What are the organization needs, issues, problems for which you want to explore, in collaboration with our students, a potential information technology solution?**

International Custom Products is a Canadian based textile firm that services many institutional, government, and defense contractors. As such ICP strives towards full NIST 800-171 compliance as well as the CMMC framework. At present systems are disparate without a centralized management platform to provide tracking and approvals. We will explore existing process flows with the students in order to develop a new process flow with documentation within the power apps framework. The students will also create proper UML diagrams to provide to the developer team at Golden Integrated Solutions who is their Managed Services Provider. This project will be put into a proper project charter by the students to learn to effectively manage the scope, and life cycle of the software development process. The goal of this project is to develop a system using Microsoft Power Apps to automate approvals, logs for access to systems, and increased organizational efficiency.

2. **What days and times of the week are most suitable for your organizations to schedule meetings with the student team?**

Tuesdays/Fridays 2-3pm

3. **Additional comments and /or questions?**

n/a

Responsibilities of the Partner Organization

1. Meet students weekly for at least one hour to answer their questions, and to provide timely feedback on their work and project progress.
2. Provide a mid-semester written feedback to the supervising faculty about project progress.
3. Read the student final report and provide timely feedback to students.
4. Submit an end-of-semester written feedback to the supervising faculty about the final student solution, after reading the final student report.

Mid-Semester Organization Feedback

Project Name: *ITM 900 Capstone Project* | Access Controls Management System

Project Progress:

What is the progress state of the project?

Progress is going well given the timeline and Gantt chart expectations.

Cooperation, Commitment, Contributions and Attitudes:

Comment on the level of cooperation of the student team with the partner organization, their display of positive attitudes, timely attendance of scheduled meetings, and responsiveness to the concerns and issues raised by the partner organization.

The student group is extremely keen in delivering the components asked and analyzing the data given to produce proper documentation.

Focus & Quality:

Provide feedback on the degree of focus on the tasks at hand, the quality of the output and the team's demonstrated ability for self-directed work.

The quality of the work produced is of professional level. We are impressed with the output of the project charter, gantt, bpm work flows and understanding of the project and NIST requirements surrounding them.

Communication:

Comment on the team's demonstrated ability to effectively interact with the partner organization during and outside meetings and to communicate concerns, issues and results of their project work.

We have 2 meetings per week that has aided in good communications with all stakeholders and what is required.

Additional Comments:

Provide any other additional comments.

We are proud of this student crop that TMU has produced in being able to execute real life scenarios and be able to be a driving force behind a project to move towards completion in a limited time frame. Would highly recommend this student group, and can not wait to see what they can accomplish in the future.

End-of-Semester Organization Feedback

Project Name: ITM 900 Capstone Project | Access Controls Management System

Project Outcomes:

1. **Does the solution meet the specified requirements of the project?**

The solution did meet the specified requirements of the project that was delivered in the requested project charter.

2. **Does the solution meet the overall objective of the project?**

The objectives for ICP Defense were completed to create a system to comply towards NIST compliance to track system access from users to control access to CUI.

3. **Comment on the overall quality of the solution:**

The quality of the solution was robust in the documentation provided in order to do the programming, work flows, to get to an end product that ICP defense is happy with.

4. **Are you satisfied with the student performance in delivering a feasible solution that meets the identified needs of your organization? Explain:**

Having 2 meetings a week with the students, and their enthusiasm to rush and build what was requested was an unexpectedly great experience for us that really helped propel the project forward. The student group had specifically identified what was needed from a documentation, project flow, and deliverables for the project.

Cooperation, Commitment, Contributions and Attitudes:

Comment on the level of cooperation of the student team with the partner organization, their display of positive attitudes, timely attendance of scheduled meetings, and responsiveness to the concerns and issues raised by the partner organization.

The students had very smartly organized themselves into separate collaborative teams that was able to communicate on a business and technical level to put together great contributions towards the project. The attitudes were very positive in all of our interactions, and there were no issues with attendance even with such a tight and frequent meeting schedule. There were action items that were always delivered from each of the meetings.

Focus & Quality:

Provide feedback on the degree of focus on the tasks at hand, the quality of the output and the team's demonstrated ability for self-directed work.

We were thoroughly impressed with the quality of work from the students, not having had any previous working and project management experience. We had given the students macro goals and objectives, and they had work to beyond our expectations to deliver material that was useful for the programmers to build out the Microsoft Power Apps with little to no variation of the program after the initial testing phase.

Communication:

Comment on the team's demonstrated ability to effectively interact with the partner organization during and outside meetings and to communicate concerns, issues and results of their project work.

The TMU student team was able to effectively interact with the partner organization on various levels, including with the VP, the Managed Services Provider - Golden Integrated Solutions, as well as their team of both the governance team, and programming team.

Additional Comments:

Provide any other additional comments.

On behalf of both ICP Defence and Golden Integrated Solutions, we want to thank the student group for their work and would be more than happy to provide a reference for the future for any and all of them. It is not often in our past experiences that the projects can be completed to this level of detail and enthusiasm. The students were an absolute delight to work with and had the utmost respect for all communications and details towards the work that they had provided. We do wish all the best to all of the students and hope that one day our paths may cross again on a professional level.

References

- OpenAI. (2024). *ChatGPT* [Computer software]. Retrieved from <https://openai.com/chatgpt>
- Fortinet. (2024). *NIST Compliance*.
<https://www.fortinet.com/resources/cyberglossary/nist-compliance>
- National Archives and Records Administration. (2016, December 6). *Marking Controlled Unclassified Information*.
<https://www.archives.gov/files/cui/documents/20161206-cui-marking-handbook-v1-1-20190524.pdf>
- National Archives and Records Administration. (n.d.). *Cui category: Export controlled*.
<https://www.archives.gov/cui/registry/category-detail/export-control.html>
- Ross, R., Guissanie, G., Riddle, M., Dempsey, K., & Pillitteri, V. (2020, February). Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations. *NIST SP 800-171 Rev. 2 - Doi.org*.
<https://doi.org/10.6028/NIST.SP.800-171r2>
- Spencer, T. (2019, October 8). *What is the NIST SP 800-171 and who needs to follow it?*. NIST.
<https://www.nist.gov/blogs/manufacturing-innovation-blog/what-nist-sp-800-171-and-who-needs-follow-it-0>